
Protocolos de autenticación, autorización y control de acceso

PID_00287478

Juan Carlos Fernández Jara
Antoni Martínez-Ballesté
Agustí Solanas
Jordi Castellà-Roca

Juan Carlos Fernández Jara

Antoni Martínez-Ballesté

Agustí Solanas

Jordi Castellà-Roca

El encargo y la creación de este recurso de aprendizaje UOC han sido coordinados por el profesor: Jordi Serra Ruiz

Primera edición: febrero 2022

© de esta edición, Fundació Universitat Oberta de Catalunya (FUOC)

Av. Tibidabo, 39-43, 08035 Barcelona

Autoría: Juan Carlos Fernández Jara, Antoni Martínez-Ballesté, Agustí Solanas, Jordi Castellà-Roca

Producción: FUOC

Todos los derechos reservados

Ninguna parte de esta publicación, incluido el diseño general y la cubierta, puede ser copiada, reproducida, almacenada o transmitida de ninguna forma, ni por ningún medio, sea este eléctrico, mecánico, óptico, grabación, fotocopia, o cualquier otro, sin la previa autorización escrita del titular de los derechos.

Índice

Introducción.....	5
Objetivos.....	7
1. Técnicas de identificación y autenticación.....	9
1.1. Contraseñas	10
1.1.1. Vulnerabilidades	11
1.1.2. Almacenamiento seguro de contraseñas	13
1.2. Certificados electrónicos	14
1.2.1. Sistemas de clave asimétrica	14
1.2.2. Infraestructura de clave pública	17
1.2.3. Firma digital	19
1.3. <i>Token</i> de seguridad	26
1.3.1. Dispositivos OTP	29
1.3.2. DNI electrónico	31
1.4. Biometría	33
1.5. Legalidad en identificación y firma electrónica	35
1.5.1. eIDAS	36
1.5.2. <i>Cloud Signature Consortium</i>	37
2. Ciclo de vida de la identidad digital.....	39
2.1. Alta de usuarios	39
2.1.1. Confirmación no presencial de la identidad	39
2.2. Procedimiento de autenticación	41
2.2.1. Autenticación mediante contraseña	43
2.2.2. Autenticación mediante certificados electrónicos	44
2.2.3. Autenticación <i>single sign-on</i>	46
2.3. Baja de usuarios	47
2.3.1. Baja de contraseñas	47
2.3.2. Baja de certificados electrónicos	48
3. Control de acceso.....	49
3.1. Fases del desarrollo de un sistema de control de acceso	50
3.2. Políticas de acceso: concepto y elementos básicos	52
3.3. Tipos de control de acceso	53
3.3.1. Control de acceso obligatorio	54
3.3.2. Control de acceso discrecional	55
3.3.3. Control de acceso basado en roles	58
Resumen.....	60

Bibliografía.....	61
--------------------------	-----------

Introducción

La proliferación de los sistemas informáticos ha ocasionado que la identidad de los usuarios se haya convertido en un factor clave estrechamente relacionado con la seguridad. Ya en los primeros sistemas, que solo admitían su uso por parte de un operador, se debía controlar el acceso a la máquina y las acciones que se hacían.

El desarrollo de sistemas *mainframe* con múltiples terminales posibilitó el trabajo multiusuario: cada usuario creía disponer de la máquina en su totalidad, cuando en realidad los recursos estaban siendo repartidos en tiempo y espacio entre todos los usuarios. En ese momento se hizo necesario el desarrollo de sistemas de identificación que, en la medida de lo posible, estuviesen estrechamente ligados con el sistema operativo del ordenador central. Cada usuario debía identificarse en la propia máquina para poder hacer uso de sus recursos. Además, la identificación permitió monitorizar quién usaba cada recurso y en qué momento. Ahora bien, ¿quién aseguraba que el usuario conectado al ordenador era realmente quien decía ser? La autenticación es esencial para que la identificación tenga sentido y sea útil.

La universalización de servicios accesibles remotamente basados en internet ha hecho crecer la importancia de la autenticación de la identidad. Y aún es más importante en cuanto que internet es una plataforma que permite realizar acciones que implican dinero (comprar por internet, presentar la declaración de la renta, etc.) o un control de la privacidad del usuario (redes sociales, documentos en la nube, etc.). En este sentido, la firma digital y las tecnologías relacionadas juegan un papel clave en la autenticación segura.

En este módulo estudiaremos los distintos métodos de identificación y su autenticación, desde las ya clásicas contraseñas hasta los certificados digitales, llegando hasta los dispositivos seguros de identificación y apuntando el porvenir de la identificación por medio de la biometría. También se dará una visión de las técnicas de control de acceso y sus metodologías de implantación.

En el módulo estudiaremos las técnicas básicas de autenticación y control de acceso. Sobre la autenticación de la identidad de los usuarios, se estudiará en qué consiste la autenticación y se expondrá una panorámica de los distintos tipos de medios que se pueden utilizar. También estudiaremos conceptos relacionados con el ciclo de vida de la identidad digital, desde la creación de esta hasta su baja, pasando por detalles para tener en cuenta a la hora de utilizar las herramientas. El módulo se centra, en general, en las tecnologías usadas para autenticación en escenarios basados en internet.

Finalmente, se realiza una panorámica de los sistemas de control de acceso, estudiando las fases de un sistema de control de acceso, las políticas de acceso y los tipos de control de acceso.

Objetivos

Los objetivos que el estudiante habrá alcanzado al finalizar este módulo son los siguientes:

1. Comprender qué es la autenticación de la identidad.
2. Conocer técnicas y conceptos relacionados con las contraseñas.
3. Comprender el funcionamiento del certificado electrónico.
4. Conocer los dispositivos de usuario que se pueden utilizar en la autenticación.
5. Conocer las técnicas que proporciona la biometría para la identificación y autenticación.
6. Conocer la estructura del DNI electrónico.
7. Conocer el marco legal para la identificación y firma electrónica.
8. Comprender los pasos necesarios para dar de alta usuarios de un servicio telemático.
9. Comprender los mecanismos de autenticación en un servicio telemático.
10. Conocer el procedimiento de la baja de usuarios de un servicio telemático.
11. Comprender qué es el control de acceso.
12. Conocer las fases y políticas del control de acceso.
13. Comprender el funcionamiento de los principales tipos de control de acceso.

1. Técnicas de identificación y autenticación

La identificación digital forma parte indisoluble de la mayoría de los servicios en internet y las TIC. Por ejemplo, para colgar un vídeo en un servidor, se pide que el usuario esté dado de alta en el servicio y se identifique para poder llevar a cabo la publicación del contenido. Por otra parte, para utilizar una red social, es preciso que el usuario esté registrado. Asimismo, los contactos de esta red también deben estar convenientemente identificados. Para realizar acciones tan variadas como hacer un pago mediante tarjeta de crédito, utilizamos esta misma tarjeta para identificarnos, o bien para hacer gestiones bancarias por internet, lo primero que haremos es especificar quién somos.

Esta identificación digital puede ser relativamente sencilla. Basta con disponer de un nombre de usuario, usar como identificador la dirección de correo electrónico o, en el caso de un pago, usar el número de tarjeta de crédito. Ahora bien, para la mayoría de los servicios, además de la identificación digital, es necesaria una autenticación de esta identidad.

Mediante la autenticación de la identidad, el servicio se asegura de que el usuario es quien dice ser.

El concepto de «quien dice ser» lo resuelve el identificador de usuario: mediante una cadena de caracteres se denota cuál es la identidad del usuario. Y para demostrar la autenticidad de la identidad del usuario se pueden usar cuatro aproximaciones distintas:

- 1) El usuario es quien dice ser si demuestra conocer algo que solamente este conoce. Por ejemplo, conoce una palabra secreta de acceso.
- 2) El usuario es quien dice ser si posee algún objeto, como por ejemplo una tarjeta magnética. Un ejemplo no relacionado con la informática podrían ser las llaves de casa: en principio, es el propietario quien las posee.
- 3) El usuario es quien dice ser si posee alguna característica física que solo él tiene: por ejemplo, la huella dactilar.
- 4) El usuario es quien dice ser si es capaz de hacer algo de forma única: por ejemplo, el patrón de escritura o la forma de andar.

Login

Para hacer referencia al identificador de usuario se utiliza el término *login*.

Pese a tratarse de cuatro formas de abordar la autenticación de la identidad, no existe una frontera clara entre algunas de ellas. Además, es perfectamente posible el uso de varias de estas técnicas de forma combinada para conseguir mayores grados de seguridad.

Ejemplo

Disponer de una tarjeta con códigos de seguridad para permitir operaciones bancarias por internet (tarjeta de coordenadas) podría verse como una mezcla entre los dos primeros casos: el usuario posee la tarjeta, pero podría decirse que es conocedor de una información, aunque en este caso la tenga escrita.

Asimismo, todas estas formas de abordar la autenticación no están exentas de problemas de seguridad. Por ejemplo, la tarjeta con códigos podría ser robada y usada por otro usuario. Otro caso podría ser la obtención de una clave de acceso mediante un correo electrónico fraudulento.

La usurpación de identidad consiste en que una entidad use con éxito el mecanismo de identificación que identifica a otra identidad.

La identificación no solo es un paradigma aplicable al acceso a servicios de internet, sino que también es aplicable para garantizar la autoría de documentos de cualquier tipo. La digitalización permite el intercambio de documentos en cualquier formato digital entre diferentes individuos. En este campo, la firma electrónica permite, aparte de garantizar que el documento no haya sido modificado en tránsito, conocer de forma inequívoca la identidad del firmante del documento.

En este apartado se exponen las técnicas y tecnologías para implantar la identificación y autenticación de usuarios, tanto para el acceso a servicios de internet como para el intercambio de documentos.

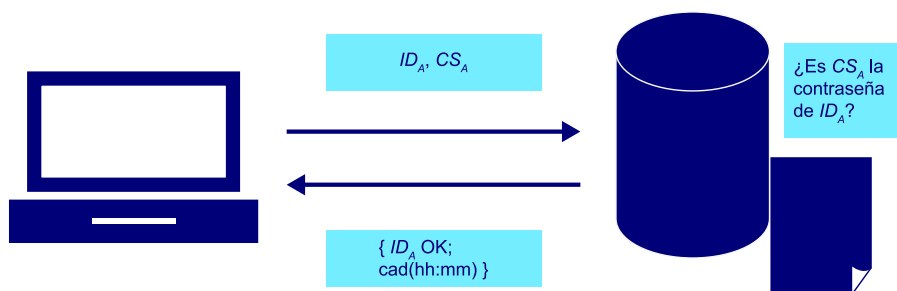
1.1. Contraseñas

La autenticación por medio de contraseñas es relativamente sencilla: el usuario A envía su identificador ID_A y acto seguido su contraseña CS_A . La implementación del protocolo de identificación puede precisar que ambas informaciones se manden en un mismo mensaje, o bien que primero se pida el nombre de usuario y después la contraseña.

Esta contraseña es usada por el servicio para validar la identidad del usuario. Si A es el único conocedor de CS_A , es altamente probable que el usuario sea realmente A . En la figura siguiente, el usuario utiliza su contraseña para validarse al servicio. Este dispone de una lista de pares con usuarios y contraseñas para comprobar las identidades. Ante una contraseña correcta, el servicio manda

un mensaje de autenticación correcta al equipo del usuario. Nótese que este incluye una hora de caducidad de esta autenticación, tras la cual el usuario deberá volver a autenticarse.

Figura 1. Esquema de funcionamiento de autenticación mediante contraseña



La contraseña es una cadena de caracteres de longitud arbitraria. En algunos escenarios, se usa una versión reducida de la contraseña, formada tan solo por unos pocos números. En este caso la contraseña se conoce con el nombre de *PIN*.¹ De todos modos, en algunos entornos se utiliza el término *PIN* cuando en realidad la contraseña está formada tanto por letras como por números.

⁽¹⁾PIN son las siglas de *personal identification number*.

Así como un mismo servicio o sistema no permite que haya dos usuarios con el mismo identificador, es perfectamente posible que dos o más usuarios tengan la misma contraseña.

1.1.1. Vulnerabilidades

El mecanismo de autenticación por contraseña es uno de los más utilizados hoy en día por la gran mayoría de servicios de internet. Esto ha llevado a que sea uno de los mecanismos más vulnerables. Un atacante utilizará diferentes tipos de ataques para lograr obtener de forma ilícita la contraseña de un usuario para así poder suplantar su identidad. A continuación, se describen las principales vulnerabilidades:

- **Phishing:** un atacante hace creer a un usuario que está accediendo a un servicio legítimo solicitando su nombre de usuario (o dirección de correo) junto a la contraseña de acceso.
- **Fuerza bruta:** un atacante utiliza capacidad de computación para realizar un gran número de intentos de acceso a un servicio utilizando diferentes combinaciones de contraseña para lograr averiguar la contraseña lícita de un usuario. En esta categoría también encontramos ataques de diccionario, sistema por el que un atacante trata de averiguar la contraseña utilizando todas las palabras de un diccionario. El diccionario suele estar compuesto por palabras gramaticalmente correctas en diferentes idiomas y por otras combinaciones de contraseñas comúnmente utilizadas, como podría ser «123456», etc.

- **Ingeniería social:** un atacante trata de manipular psicológicamente y mediante el engaño a un usuario para que revele la contraseña por cualquier medio (correo electrónico, SMS, llamada telefónica, etc.).
- **Ataques de *malware*:** en esta categoría se utiliza un software malicioso que puede ejecutarse tanto en el dispositivo del usuario o en los servidores de los servicios para extraer información sensible como pueden ser las contraseñas de los usuarios.

Afortunadamente, se dispone de una gran cantidad de consejos y técnicas para mejorar la seguridad de la contraseña:

- **Cambiar la contraseña por defecto.** Cuando en el proceso de alta el usuario no decide cuál es su contraseña, el sistema le proporciona una. Es altamente recomendable que el usuario la cambie a una que le sea más fácil de recordar y que sea «nueva» tan pronto como le sea posible.
- **Aspecto de la contraseña.** Es aconsejable una longitud mínima, así como la combinación de letras (mayúsculas y minúsculas), números y, a poder ser, otros caracteres. Desafortunadamente, algunos sistemas limitan el conjunto de caracteres posible, o incluso limitan la longitud máxima de la contraseña. El objetivo de esta medida es aumentar el espacio de búsqueda y dificultar las posibles repeticiones de contraseñas.
- **No usar contraseñas obvias.** Es evidente, sobre todo para evitar los ataques de búsqueda inteligente.
- **Usar medidores de seguridad de contraseña.** Muchos sistemas informan de la calidad de la contraseña elegida, en relación con la seguridad que ofrece. Estos sistemas se basan en las recomendaciones anteriores para decidir sobre la seguridad de la contraseña escogida.
- **Forzar periódicamente el cambio de contraseña.** Si la contraseña del usuario ha sido obtenida por algún atacante, el cambio periódico hace que la contraseña usurpada ya no tenga validez.
- **Permitir un número máximo de intentos fallidos.** Mediante esta técnica se limita claramente el éxito de los ataques de fuerza bruta. Cuando se llega al máximo de intentos se bloquea la cuenta.
- **Solicitar códigos de autorización en aquellas operaciones que precisen de más seguridad.** Estos códigos suelen encontrarse en una tarjeta de coordenadas específica del usuario, aunque también podría usarse un *token*. En este caso es recomendable que el código de autorización sea de un solo uso.

Contraseñas obvias en Hotmail

Tras un ataque masivo, se revelaron cuáles son las contraseñas más usadas en Hotmail. La clave que apareció con más frecuencia fue «123456».

1.1.2. Almacenamiento seguro de contraseñas

Uno de los mayores retos de los diferentes software y servicios de internet es salvaguardar en un servidor la información confidencial necesaria para poder validar la contraseña de los usuarios presentada durante un proceso de autenticación.

La forma menos recomendable de almacenar la contraseña es en texto en claro, es decir, almacenar la contraseña en su forma original. Un acceso indebido al sistema de almacenamiento expone la contraseña de todos los usuarios.

Aplicar un algoritmo de cifrado de datos sobre la contraseña para su almacenamiento soluciona parcialmente el problema anterior, pero el robo de la clave privada utilizada para el cifrado expone de nuevo todas las contraseñas de los usuarios. Adicionalmente, un uso malintencionado de la clave de cifrado por un administrador del sistema podría comprometer las contraseñas originales de todos los usuarios.

Los mecanismos que se apliquen para el almacenamiento de contraseñas deben tener en cuenta siempre la potencial capacidad de que un atacante obtenga una copia ilícita de los datos almacenados en el servidor para la validación de contraseñas. El objetivo es dificultar al máximo que un atacante pueda aplicar un ataque de fuerza bruta, incluso si dispone de una copia de esta información confidencial. A continuación, se exponen los mecanismos de protección más importantes. Se recomienda aplicar el mayor número simultáneo de los siguientes mecanismos:

1) **Función criptográfica *hash***. Se trata de aplicar un algoritmo matemático que es capaz de transformar un conjunto de datos de cualquier tamaño en un conjunto de datos de longitud fija. Una función *hash* es irreversible, lo que significa que a partir de los datos de salida de una función *hash* es muy difícil obtener el conjunto de datos original. De esta forma, es posible almacenar los datos de salida de la función *hash* aplicada sobre la contraseña. Aunque un atacante no podrá obtener la contraseña original a partir de estos datos, podría aplicar un ataque de fuerza bruta por diccionario. Un ataque de este tipo se basa en calcular el *hash* de las contraseñas más comunes y almacenar estos valores en una tabla, a la que llamamos *diccionario*. Entonces, en el momento de realizar el ataque, el atacante compara el *hash* de la contraseña del usuario con las entradas almacenadas en el diccionario. Algunas funciones interesantes de *hashing* son:

- PBKDF2 (RFC2898)
- bcrypt
- scrypt

2) **Salts**. Se trata de un conjunto de datos aleatorios que se concatena a la contraseña del usuario antes de aplicar una función criptográfica *hash*. El *salt* se almacena juntamente con el valor *hash*. Esto permite que, aunque el usuario haya escogido una contraseña típica que pueda aparecer en diccionarios, el valor *hash* almacenado en el sistema y el valor *hash* en el diccionario no coincidan, de esta forma se evitan este tipo de ataques. Veamos un ejemplo a continuación.

Ejemplo de salt

- El *hash* SHA-256 de la contraseña «123456» es el siguiente: «8d969eef6ecad3c29a3a629280e686cf0c3f5d5a86aff3ca12020c923adc6c92». Con esta información se podría identificar qué usuarios tienen la misma contraseña «123456».
- Para almacenar la contraseña de cada usuario de forma segura, para cada contraseña que deseemos almacenar creamos un *salt* aleatorio, por ejemplo, «t748djf».
- Concatenamos el *salt* a la contraseña original, en este caso, «t758djf123456».
- Calculamos el *hash* SHA-256 sobre el nuevo valor y obtenemos esto: «f7b918f4ac3f2c51c34a0a4a1df79a9af0e15a7b667f4ffa820ea86296a05084».
- Como se puede observar, el nuevo valor difiere del original. Utilizando un *salt* diferente para cada usuario, obtendremos un *hash* diferente para cada usuario, de esta manera se dificulta la tarea de obtención de contraseñas.

3) **Complejidad computacional**. La capacidad de computación cada vez es mayor, mientras que la capacidad del ser humano para recordar contraseñas más largas y seguras sigue prácticamente intacta. Para poder mitigar este problema se requiere aplicar funciones de *hash* lentas y de forma iterativa. Es decir, aplicar la misma función de *hash* desde miles a millones de veces. Esto permitirá aumentar la complejidad para abordar un ataque de fuerza bruta computacionalmente.

1.2. Certificados electrónicos

La firma o los certificados electrónicos son dos de las utilidades que sirven a modo de autenticación de identidad. A continuación, revisamos algunos conceptos básicos sobre criptografía de clave pública.

1.2.1. Sistemas de clave asimétrica

Los sistemas de criptografía de clave pública (o asimétricos) se basan en el uso de dos claves: la **clave privada**, o secreta, que solo conoce el propietario, y la **clave pública**, la cual, como su nombre indica, puede ser conocida por otras entidades sin que esto tenga consecuencias en la seguridad del sistema. En cambio, la clave privada debe estar perfectamente custodiada. Los matemáticos, criptógrafos y organismos han propuesto sistemas y estándares de sistemas de clave pública. Estos criptosistemas están basados en funciones matemáticas con trampa que permiten realizar una operación en un sentido fácil-

mente, pero su inversa no es posible computacionalmente calcularla sin una información extra (trampa). Es decir, con la clave pública se realiza una operación que únicamente se puede invertir con la clave privada, y viceversa.

El uso de la clave pública o la clave privada depende de la operación que hay que realizar:

- Para dar **confidencialidad** a un mensaje que «A» (emisor) envía a «B» (receptor), es decir, que ningún otro usuario pueda conocer el contenido del mensaje, «A» usará la clave pública de «B» (que cualquier usuario puede obtener). Cuando «B» reciba el mensaje, usará su correspondiente clave privada para acceder a su contenido. Es recomendable que la clave privada esté protegida y sea necesario proporcionar una contraseña para acceder a ella.
- Para dar **autenticidad** a un mensaje que «A» manda a «B», lo que se conocería como *firma electrónica*. «A» usa su clave privada para firmar el mensaje, esta operación solo la puede realizar el poseedor de la clave privada. Cuando «B» reciba el mensaje comprobará la validez de la firma. En primer lugar, deberá obtener la clave pública de «A» y, a continuación, realizará la operación inversa a la firma (verificación).

La firma electrónica permite alcanzar tres propiedades relacionadas con la seguridad de la información. Mediante la firma electrónica de un mensaje (o fichero) «M» mandado de «A» a «B»:

- 1) Se asegura que nadie ha modificado el mensaje firmado. Asegura, pues, la **integridad** del mensaje. La modificación de un único bit de la firma o del mensaje firmado dará lugar a una verificación incorrecta.
- 2) Se asegura que el mensaje lo ha firmado «A», es decir, **asegura la identidad** del firmante (o **autenticación de origen** de «M»). La operación únicamente la puede realizar el propietario de la clave privada.
- 3) Ante cualquier tercera parte, al ser «A» el único que conoce su clave privada, se podrá demostrar que fue «A» quien firmó «M». O dicho al revés, «A» **no podrá repudiar** la firma electrónica realizada del mensaje. Únicamente «A» puede realizar esta operación (firma).

El hecho de no compartir una clave entre quien cifra y quien descifra, cosa que ocurre en los sistemas de clave compartida (o simétricos), proporciona estas dos últimas características de seguridad. Así pues, los sistemas de clave compartida no garantizan completamente la identidad y el no repudio.

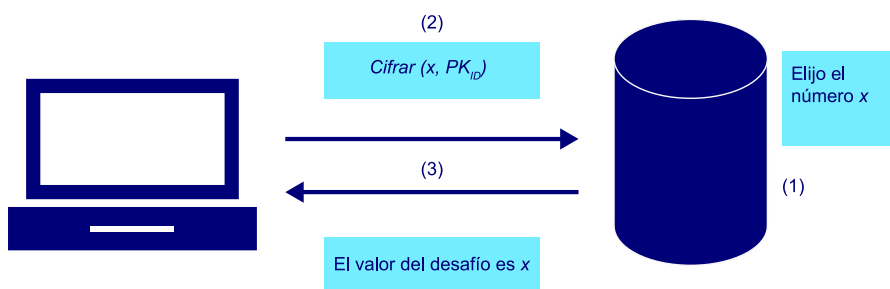
La firma electrónica garantiza las propiedades de integridad, identidad y no repudio.

En el ámbito de la **autenticación en servicios**, la criptografía de clave pública permite el **sistema desafío-respuesta**. El servicio obtiene la clave pública de la identidad que se autentica (PK_{ID}). Entonces, el servicio elige unos datos aleatorios, los cifra con PK_{ID} y manda este desafío a la identidad. Si la identidad es quien dice ser, debería tener acceso a la clave privada con la que descifrar el desafío, con lo cual deberá poder mandar de vuelta el número aleatorio con que el servicio lo ha desafiado.

Otras formas de desafío-respuesta

También se puede realizar un desafío-respuesta mediante una clave secreta compartida. Este caso es habitual con el uso de *tokens*, que estudiaremos más adelante.

Figura 2. Esquema del sistema de autenticación desafío-respuesta



En el ámbito de autenticidad y autoría en el **intercambio de documentos**, la criptografía de clave pública permite el **sistema de firma digital**. El proceso de alto nivel para este sistema es:

1) Remitente:

- se obtiene el documento digital que hay que firmar;
- se calcula el *hash* del documento original que se desea firmar;
- se realiza un cifrado asimétrico de los datos de resumen con la clave privada del remitente (quien quiere firmar el documento);
- se completa el documento digital incrustando la firma digital (paso anterior) para su posterior envío al receptor del documento.

2) Receptor:

- se obtiene el documento digital firmado;
- se identifica la clave pública del remitente;
- se descifra la firma digital utilizando la clave pública del remitente;

- se compara el resultado de descifrar la firma digital con el resumen de los datos del documento original. Si la comparación es positiva, es posible afirmar que el documento no ha sido modificado en tránsito y que el remitente es quien dice ser, en otras palabras, se identifica al remitente de forma inequívoca.

El uso de la firma electrónica y, en general, de los sistemas de clave pública plantea un gran problema, que trataremos a continuación: cuando se obtiene la clave pública de una entidad (correo electrónico, servidor de internet, etc.), ¿cómo se asegura que realmente corresponde a la entidad identificada?

1.2.2. Infraestructura de clave pública

Una infraestructura de clave pública, PKI (*public key infrastructure*, en inglés), es una capa funcional situada conceptualmente por encima de los elementos criptográficos básicos de clave asimétrica que proporciona las funciones de gestión con máxima seguridad y confianza.

Una PKI se basa en **certificados digitales** y en los **servicios de confianza** que se erigen sobre ellos. Un **certificado digital** es un componente digital que incluye los datos de identidad de una persona o entidad. La información básica que contiene un certificado es la siguiente:

- La identidad que se certifica, por ejemplo, una dirección de correo electrónico o el número de DNI de un ciudadano.
- El periodo de validez, que es la fecha a partir de la cual el certificado no será reconocido como válido.
- La clave pública que se certifica, que se usará directamente para comprobar la firma.
- El nombre del emisor del certificado. En general, se trata de una **autoridad de certificación**, un organismo que puede expedir certificados de clave pública. Esta autoridad da fe de que la clave pública pertenece a la identidad especificada en el certificado.

Ejemplos de certificado electrónico

Cuando nos conectamos a un sitio web seguro se obtiene un certificado cuya misión es autenticar la identidad del servidor. Asimismo, cuando realizamos una firma electrónica en un documento, esta firma se acompañará, en general, de un certificado que dé fe de la validez de la clave pública que se deberá usar para comprobar la firma.

Este último elemento es crucial para el funcionamiento de los sistemas de clave pública. Hemos visto que una clave pública está autenticada mediante un certificado. Pues para confiar en un certificado se debe confiar en su emisor. Esto es, si el emisor no es de confianza, el certificado se deberá rechazar. Si, por el contrario, el emisor es de confianza, el certificado es aceptado y, en consecuencia, se dará por buena la clave pública que certifica.

Los componentes básicos de una PKI son:

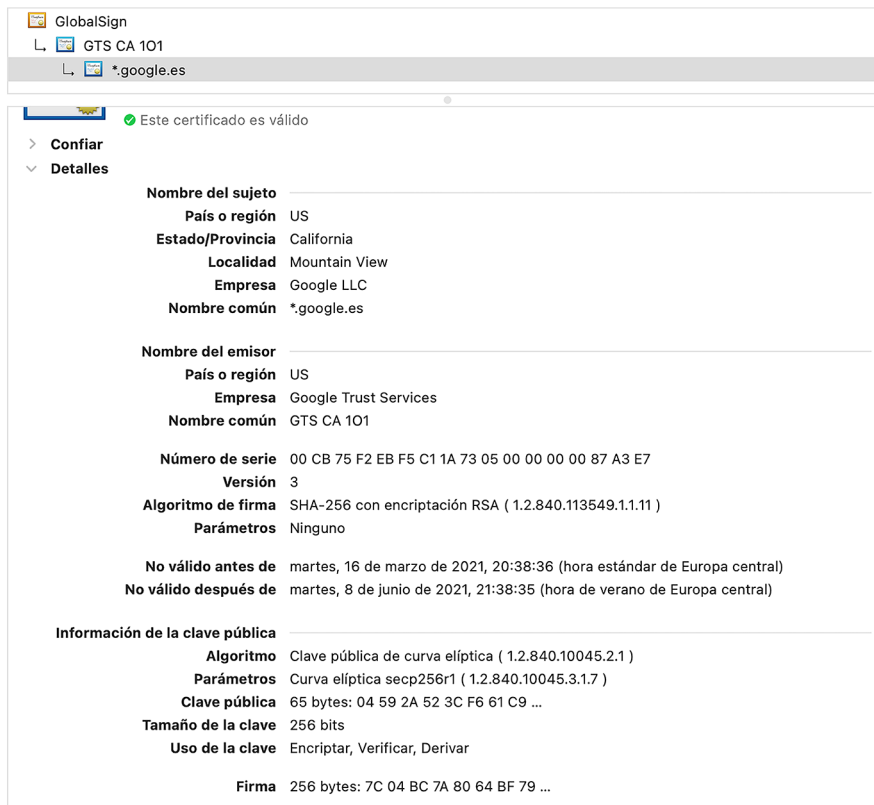
- **Autoridad de certificación (CA):** autoridad encargada de emitir certificados digitales a personas o entidades.
- **Autoridad de registro (RA):** autoridad encargada de comprobar físicamente que la persona o entidad que recibirá un certificado digital realmente es quien dice ser. Se trata del punto de entrada para la generación de un certificado digital con la identidad comprobada.
- **Autoridad de validación (VA):** autoridad encargada de mantener una lista de los certificados que han dejado de ser válidos. Un motivo típico por el cual la persona o entidad dueña de un certificado digital puede ordenar su revocación y, por lo tanto, la inclusión del certificado en esta lista, es sospechar que las claves privadas asociadas al certificado hayan sido comprometidas por terceros.
- **Autoridad de sellado de tiempo (TSA):** autoridad encargada de crear marcas de tiempo para demostrar la existencia de cierta información antes de un determinado momento.

Los componentes de una PKI deben estar operados por entidades reconocidas y que sean consideradas fiables por las personas o entidades que van a interactuar en el proceso de generación y verificación de firmas digitales, para construir, así, el marco de confianza necesario.

Además, los operadores de estos servicios de confianza deberán cumplir normativas y pasar auditorías de seguridad que garanticen que el propio servicio de confianza no está comprometido.

La figura siguiente muestra las propiedades del certificado de servidor del servicio de búsqueda web www.google.es. Como se puede observar, el **nombre del sujeto** identifica al servidor «*.google.es», el emisor del certificado es la CA GTS CA 101 de la propia empresa Google y su periodo de validez es hasta junio de 2021.

Figura 3. Propiedades del certificado de servidor de www.google.es



Como se ha podido observar, una PKI se basa totalmente en la confianza en las autoridades certificadoras (CA). Un sistema informático de usuario (ordenador, navegador, etc.) dispone, por defecto, de unas entidades emisoras de certificados de confianza. En este sentido, los sistemas tienen un almacén de certificados en el cual hay una colección de entidades de confianza que ha sido preaprobada por el creador de cada sistema (Microsoft, Mozilla, etc.). Si se recibe un certificado que ha sido emitido por una autoridad de confianza, este se acepta sin más (de hecho, el usuario no es ni consciente de este hecho). La dificultad surge cuando el emisor del certificado no está en la lista de autoridades de confianza del sistema. En este caso, el usuario deberá gestionar el alta de aquellas nuevas autoridades de confianza en el sistema o software específico.

Las grandes empresas certificadoras internacionales, así como organismos certificadoros dependientes de los gobiernos, ya son reconocidas por la mayoría de los sistemas.

1.2.3. Firma digital

La definición semántica de *firma digital* es: mecanismo criptográfico para verificar la autenticidad del origen de la información, así como verificar que dicha información no ha sido modificada desde su generación.

Existen firmas digitales basadas en mecanismos criptográficos de clave simétrica y asimétrica. Tal como se ha visto con anterioridad, la criptografía de clave asimétrica permitirá una gestión óptima de la gestión de la identidad de entidades.

PKCS#1 es el estándar técnico criptográfico que ha de cumplir una firma digital. PKCS#1 forma parte del grupo de estándares llamados PKCS (*public-key cryptography standards*). Se puede ver detallada la definición técnica de este estándar en la publicación RFC3447.

En resumen, la estructura resultante de aplicar el estándar PKCS#1 usando una clave privada asociada a un certificado es lo que podemos llamar **firma digital**.

Un punto flaco de la firma digital PKCS#1 es que no incluye información sobre el contexto de la firma. No incluye datos sobre el firmante, ni el formato de datos, ni los datos firmados, ni una marca de tiempo de cuándo se firmaron los datos, ni las características funcionales que se quiere incluir a la firma digital.

Para cubrir múltiples casos de uso y poder incluir la información necesaria de contexto al firmar un documento, el mercado se inundó de estándares técnicos que permiten aplicar la firma digital «en crudo» sobre un conjunto de documentos con un formato determinado.

Hoy en día, los formatos de documento más comunes que requieren ser firmados son:

- **Documentos XML:** metalenguaje definido por W3C para facilitar el intercambio de mensajes y documentos legibles por diferentes plataformas heterogéneas y, a su vez, legible por el ser humano. Este formato de documentos ha sido ampliamente acogido por el mercado tecnológico y, también, por el mercado de firma digital.
- **Documentos PDF:** formato definido como ISO 32000-1 por Adobe Systems. Ampliamente conocido por su versatilidad en la portabilidad de documentos.
- **Documentos binarios:** imágenes, texto, etc.

Cada uno de estos formatos tiene una sintaxis muy diferente técnicamente; sin embargo, es necesario poder proveer a todo este tipo de documentos de las mismas características de firma digital. Para ello, surgieron un conjunto de estándares de firma digital avanzada, también conocidos como AdES (*advanced electronic signature*).

Volviendo a los formatos de documento comentados anteriormente, veamos qué estándares de firma digital los respaldan:

- **PAdES** (*PDF advanced electronic signature*): formato de firma avanzada definido por ETSI en la especificación técnica TS 102 778 para documentos PDF. Es una extensión al estándar PDF para incluir en su sintaxis la firma digital avanzada.
- **XAdES** (*XML advanced electronic signature*): formato de firma avanzada definido por W3C y estandarizado por ETSI en la especificación técnica TS 101 903. Este formato permite hacer firmas digitales avanzadas tanto de documentos XML como de documentos binarios. Básicamente, este estándar define el formato final de la firma, pero no el del formato de los datos que hay que firmar. Esto da versatilidad a la firma, motivo por el cual este estándar se ha tomado como referente en multitud de casos de uso.

Existen otros estándares relevantes de firma avanzada definidos por ETSI, como ASiC y CAdES. Además, cabe destacar que todos los formatos AdES se basan en la firma criptográfica PKCS#1 y en infraestructura de clave pública (PKI).

A continuación, veremos en detalle dos de los formatos de firma más extendidos y utilizados: XAdES y PAdES.

Firmas XML

Gracias a la facilidad que da XML para estructurar la información, el hecho de ser libre de licencias y su independencia con la plataforma, repercute en que esta tecnología sea una de las más extendidas para firmar documentos generados en web. El estándar de referencia es XML, *advanced electronic signatures*, más conocido por su acrónimo, XAdES, por lo que define formatos de firma que puedan ser válidos para realizar transacciones.

Existen varios tipos de XAdES que implementan una XML-Dsig, según el nivel de protección ofrecido. A continuación, se definen algunos de los niveles de protección de XAdES, del más básico al más extenso, donde cada uno incluye y extiende al previo:

- 1) **XAdES-BES** (*basic electronic signature*). Define la forma básica de una firma electrónica. Tiene que contener el elemento *SigningCertificate* o *ds:KeyInfo*.
- 2) **XAdES-EPES** (*explicit policy based electronic signature*). Añade información sobre políticas de firma mediante la propiedad *SignaturePolicyIdentifier*.
- 3) **XAdES-T**. Añade un campo de sellado de tiempo mediante *SignatureTimeStamp* o de un proveedor de tiempo de confianza.
- 4) **XAdES-C**. Añade referencias a datos de verificación (certificados y listas de revocación) a los documentos firmados para permitir verificación y validación sin conexión.

5) **XAdES-X**. Firma extendida con sellos de tiempo a las referencias introducidas por XAdES-C para evitar que pueda verse comprometida en el futuro una cadena de certificados, mediante las propiedades *CompleteCertificateRefs* y *CompleteRevocationRefs*.

6) **XAdES-X-L**. Firma extendida a largo plazo añadiendo los propios certificados y listas de revocación a los documentos firmados, para permitir la verificación en el futuro, incluso si las fuentes originales (de consulta de certificados o de las listas de revocación) no estuvieran ya disponibles mediante las propiedades *CertificateValues* y *RevocationValues*.

Ved también

En el subapartado 2.3.2 de este módulo estudiaremos en qué consisten las listas de revocación.

7) **XAdES-A**. Firma archivada que añade la posibilidad de *timestamping* periódico de documentos archivados por medio de las propiedades *CertificateValues*, *RevocationValues* y al menos un *ArchivedTimeStamp*. Esta firma previene que la firma del documento pueda ser comprometida posteriormente a causa de la debilidad de la firma.

El W3C es el encargado de realizar las recomendaciones y definir la sintaxis XML para gestionar firmas electrónicas, permitiendo así que una firma XML pueda firmar cualquier tipo de documento.

Existen varios tipos de firma XML, entre las que remarcamos los tres tipos más comunes:

1) **Enveloping signatures**.² La firma incluye el documento firmado dentro de un elemento *object* de la propia firma. Este tipo de firma permite almacenar firma y documento en una sola unidad.

⁽²⁾En castellano, firma.

2) **Enveloped signatures**.³ El documento firmado incluye la firma dentro del propio documento. Este tipo de firma también permite almacenar firma y documento en una sola unidad.

⁽³⁾En castellano, firma envuelta.

3) **Detached signatures**.⁴ En este caso, la firma está totalmente desacoplada del documento firmado. Se permite almacenar firma y documento en diferentes unidades. La firma incluye una referencia directa al documento que se ha firmado para poder relacionarlas.

⁽⁴⁾En castellano, firma separada.

Estructura básica del elemento `<Signature>`:

```
<Signature ID?>
  <SignedInfo>
    <CanonicalizationMethod />
    <SignatureMethod />(<Reference URI? > <Transforms>)?<DigestMethod>
    <DigestValue>
  </Reference>)+
</SignedInfo>
```

```
<SignatureValue /> (<KeyInfo />)? (<Object ID?>)*  
</Signature>
```

Para la implementación del firmado de un documento mediante XML se debe tener en cuenta que las representaciones de documentos firmados usados por la aplicación que realiza la firma y la que la verifica deben ser totalmente idénticas. De hecho, es totalmente posible que dos aplicaciones de firma electrónica distintas, al firmar un mismo documento, obtengan, cada una, un documento distinto al otro, pero ambos válidos, debido tal vez a la alteración del orden de los atributos, a los posibles espacios en blanco en las etiquetas, a los elementos vacíos, etc. Para asegurar que no haya problema, W3C define una **forma canónica**⁵ para cualquier documento XML, de esta forma, se eliminan las posibles ambigüedades en la generación de la representación de un documento. El elemento `<SignedInfo>` y el documento XML deben pasar por este proceso. Con la canonización, aseguramos que el documento se encuentra codificado en UTF-8, no existen saltos de líneas, hay todos los atributos por defecto de cada elemento, etc.

⁽⁵⁾Puede verse en www.w3.org/TR/xml-c14n2/

Firmas PDF

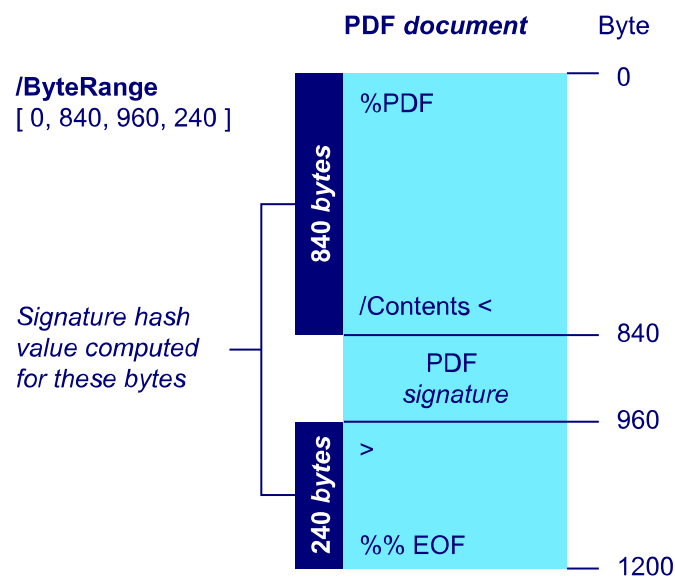
PDF es el acrónimo de *portable document format* y se trata de un formato de documentos digitales totalmente independiente de la plataforma de creación o visualización. Este estándar fue creado por Adobe Systems y definido en el ISO 32000-1.

En el estándar PDF se definen un gran conjunto de características para componer documentos digitales, como pueden ser la inclusión de texto, imágenes, archivos multimedia, hipervínculos o marcadores, entre otros. Cabe mencionar que el estándar PDF incluye también la capacidad de inclusión de firmas digitales al documento para poder dotarlo de integridad, autoría y no repudio, tal como se puede hacer sobre documentos XML.

El estándar de referencia para las firmas de documentos PDF es PAdES (ETSI TS 102 778). Existen varios tipos de PAdES que implementan el estándar de firma definido en ISO 32000-1, según el nivel de protección ofrecido.

En la siguiente figura se muestra visualmente cómo se compone una firma digital sobre un documento PDF de ejemplo:

Figura 4. Ejemplo de firma digital sobre documento PDF



Fuente: ETSI PDF Advanced Electronic Signature Profiles

Los pasos más importantes para componer un documento PDF firmado digitalmente, y que se pueden observar en el esquema anterior, son los siguientes:

- 1) Se obtiene el documento PDF original, identificado como *PDF Document* en la figura anterior.
- 2) Se incluye un diccionario de firma digital (*tag* `/Contents` en la figura). Este elemento incluirá la firma digital en formato CMS. En este paso, aún no se ha calculado la firma, ya que se está preparando el documento para ser firmado.
- 3) Se calcula el elemento `/ByteRange`, el cual incluye el rango de bytes de los datos binarios que cubrirá la firma. En este caso, desde el inicio del documento [byte 0] hasta el inicio de la firma CMS que aún no ha sido calculada [byte 840]. El *ByteRange* también incluye la parte final del PDF tras la firma CMS [desde el byte 960, incluyendo los 240 bytes siguientes]. El valor del *ByteRange* resultante es `/ByteRange [0 840 960 240]`.
- 4) Se obtienen los datos binarios del rango calculado por el `/ByteRange`.
- 5) Se aplica una función de *hash* sobre los datos binarios. El resultado obtenido serán los datos sobre los que se aplicará la firma digital.
- 6) Se crea el contenedor de la firma digital en formato CAdES (CMS).
- 7) Se incrusta la firma digital anterior en el diccionario de firma del documento PDF. Como el CMS incrustado está fuera del rango especificado por el *ByteRange*, incrustarlo en el PDF no altera la integridad de este.

A continuación, se definen algunos de los niveles de protección de PAdES, del más básico al más extenso, donde cada uno incluye y extiende al previo:

1) **PAdES Basic**: perfil básico que cumple con los requisitos especificados en la norma ISO 32000-1.

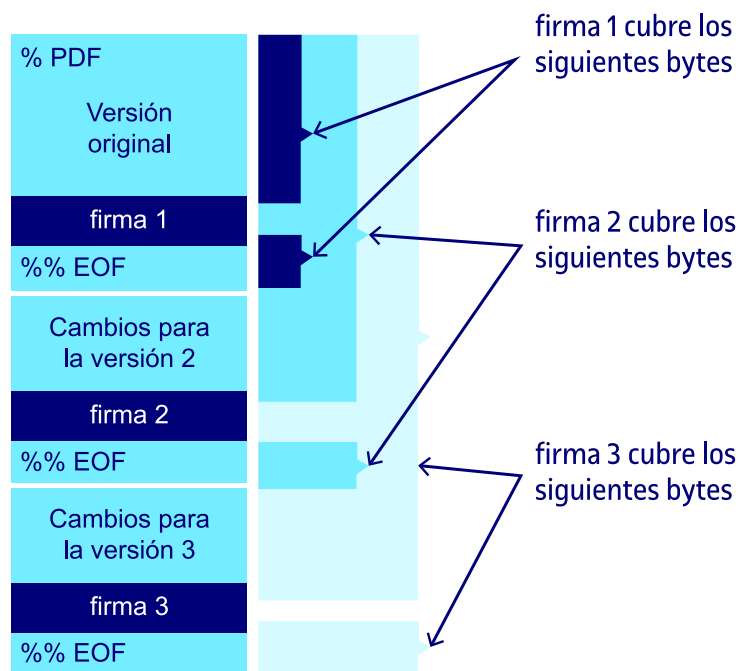
2) **PAdES-BES**: este perfil especifica una firma PDF avanzada basada en CA-DES-BES e incorpora opción de incluir en la firma un sello de tiempo (CA-DES-T).

3) **PAdES-EPES**: este perfil especifica una firma PDF avanzada basada en CA-DES-EPES. Se trata del perfil PAdES-BES anterior, añadiendo un identificador de política de firma y, opcionalmente, una referencia al tipo de compromiso adquirido.

4) **PAdES-LTV**: es el formato de firma longeva. Este perfil permite prorrogar por tiempo indefinido la validez de las firmas en formato PDF. Puede ser usado en conjunción con el PAdES Basic, PAdES-BES o perfiles PAdES-EPES. Este perfil es utilizado para garantizar que es posible validar la firma tras el paso del tiempo, más allá de la expiración del certificado del firmante original, es decir, garantiza la validación a largo plazo.

A diferencia del formato de firma de documentos XML, PDF solo permite incluir firmas de diferentes firmantes en serie. Esto significa que se pueden incluir nuevas firmas digitales sobre el documento PDF original o previamente firmado. Hay que tener en cuenta que las firmas en serie cubrirán los cambios que se hayan incluido al documento PDF desde la última firma digital. Esto permite conocer qué cambios ha sufrido el documento en cada versión firmada y garantizar la integridad de aquel contenido que realmente fue firmado por cada entidad firmante. PAdES no permite realizar firmas *enveloping* o *detached*. En la siguiente figura se puede observar la característica de firmas en serie.

Figura 5. Firmas en serie



Fuente: ETSI PDF Advanced Electronic Signature Profiles

1.3. Token de seguridad

Hasta el momento, la gran mayoría de servicios de internet usan la contraseña como herramienta de autenticación. Las redes sociales o los servicios de correo electrónico más populares son algunos ejemplos. El uso de la contraseña implica que si esta es rebelada puede ser utilizada de forma ilícita y un atacante podría suplantar la identidad del usuario.

En el caso de los certificados digitales, son generalmente usados para autenticar servicios o documentos que requieren de un nivel de seguridad elevado, por ejemplo, la página web segura de un servicio bancario en línea. Sin embargo, en algunos servicios que funcionan sobre internet ya es habitual que la autenticación de la identidad sea mediante un certificado de cliente. En general, para usar este sistema de autenticación, se acabará usando una clave privada que estará albergada en el propio sistema. Esta clave secreta debe estar protegida (cifrada), y solo se debe poder usar tras introducir una contraseña o PIN. El uso de certificados digitales implica que si la clave privada es revelada puede ser utilizada nuevamente de forma ilícita y un atacante, nuevamente, podría suplantar al usuario.

En general, como hemos comentado anteriormente, cuando se establece un mecanismo de autenticación para garantizar la identidad de un usuario, se aumentará el nivel de seguridad si el mecanismo de autenticación incluye el mayor número de garantías entre las siguientes:

- El usuario **posee** algún tipo de dispositivo que le permite autenticarse.
- El usuario muestra algo que solamente él **conoce**.

- El usuario tiene una **característica física** que solo él posee.

En este ámbito se engloban los *tokens* de seguridad, dispositivos físicos que el usuario **posee** y que le permitirán autenticarse de forma digital a un servicio. Para ello, el usuario tendrá que autenticarse delante del *token*, que le pedirá que demuestre algo que solamente él conoce o que muestre alguna característica física concreta.

Los *tokens* de seguridad son pequeños dispositivos cuyo objetivo es dar soporte al proceso de autenticación de identidad. En general se utilizan para validar la entrada a sistemas y servicios.

Ejemplo de uso de token

Hay sistemas de autenticación que usan *token*, entendiendo estos como ficheros mediante los cuales los usuarios pueden acceder a los servicios. Un ejemplo sería el sistema Kerberos, mediante el cual los usuarios obtienen, de forma transparente, ficheros con los que se autenticarán ante servicios.

Hay gran variedad de *tokens*. Por ejemplo, en cuanto a conexión al equipo, los más habituales son los que se conectan al puerto USB, aunque también los hay que usan una conexión *bluetooth* o simplemente no precisan de conexión al equipo. En cuanto a capacidad de memoria y proceso, dependerá del sistema de soporte que permita el *token*. He aquí cuatro casos combinando las anteriores alternativas:

1) El *token* guarda un valor secreto en su memoria y se comunica mediante USB con un controlador instalado en el PC. El controlador solo permite el acceso al contenido del *token* tras poner un PIN correcto. En el fondo, la información que contiene la memoria va cifrada, y es preciso que el controlador la descifre.

2) El *token* no va conectado al ordenador, pero tiene un pequeño teclado numérico mediante el cual el usuario introduce una coordenada proporcionada por el sistema de identificación. El *token* muestra en una pequeña pantalla el valor secreto correspondiente a la coordenada solicitada. Este ejemplo sería análogo a la tarjeta de coordenadas impresa que utilizan algunas entidades bancarias.

3) Un tercer caso sería un *token* con capacidades criptográficas que pudiera responder a un desafío criptográfico mandado por el sistema de identificación, usando el método desafío-respuesta. En este caso, se contempla la modalidad de desafío-respuesta usando una clave secreta compartida, o bien usando un sistema de cifrado de clave: la copia de la clave secreta que necesita el cliente está almacenada en el *token*.

4) Un último caso sería el de una etiqueta RFID,⁶ que contiene un valor que permite identificar la etiqueta. Dado que un lector de RFID interactúa con las etiquetas mediante el espectro electromagnético y sin usar conexiones físicas, el hecho de que la identificación sea segura (básicamente que esté protegida contra escuchas por parte de atacantes) supone un reto importante inherente al uso de estas etiquetas en servicios y entornos que precisen cierta seguridad.

⁽⁶⁾RFID es la abreviatura de *radio-frequency identification*, identificación mediante radiofrecuencia.

Seguridad de las etiquetas RFID

El reducido rango de lectura fijado en los dispositivos RFID dificulta el ataque, aunque no lo elimina por completo. Un atacante puede acercarse a la víctima para estar dentro del rango de lectura del RFID y, a continuación, enviar esta información mediante una conexión de alta velocidad al sistema informático para autenticarse. Por este motivo, es necesario fijar medidas de seguridad que requieran la participación del propietario en la autenticación.

Sea como fuere, el *token* es un dispositivo independiente del ordenador y puede llevarse siempre consigo. Esto acarrea un claro problema de seguridad en caso de robo del *token*. Es por ello por lo que el uso de un *token* normalmente suele alternarse con otro mecanismo de autenticación, lo que consigue que la identificación del usuario se realice mediante **dobles factores de autenticación** (2FA).

Otro elemento que puede considerarse *token* es la tarjeta inteligente. Este tipo de tarjetas se caracterizan por llevar un circuito integrado capaz de almacenar información e incluso hacer operaciones criptográficas. El uso de estas tarjetas se popularizó gracias a su aceptación como medio de pago (suponen un nivel avanzado en seguridad respecto de las tarjetas bancarias con banda magnética, puesto que para poder usarlas es necesario conocer un PIN), y también por las tarjetas SIM (*subscriber identity module*), que tienen actualmente todos los teléfonos móviles. Además, en multitud de organizaciones e instituciones el uso de los certificados digitales y tarjetas inteligentes se ha convertido en algo habitual.

Seguridad de las tarjetas inteligentes

En inglés, una tarjeta inteligente se llama *smart card*, mientras que en francés *carte à puce* ('tarjeta con chip'). Las tarjetas inteligentes son seguras contra manipulaciones. Si un atacante intenta acceder a la información que contiene la tarjeta, esta se bloquea y se elimina la información. Además, incorporan mecanismos de protección para evitar que se pueda obtener información de las claves a partir del consumo de energía o tiempo de respuesta.

Claves de un certificado digital

El elevado uso de operaciones criptográficas debilita la seguridad del par de claves que componen un certificado digital. Mediante la creación de dos pares de claves privadas y públicas, se consiguen reducir las posibilidades de debilitamiento de las claves. Uno de los pares de claves se utiliza para las operaciones de autenticación, y el otro para las de firma de documentos.

A continuación, se presentan los dos ejemplos más extendidos de dispositivos de identificación de usuarios:

- 1) dispositivos de contraseñas de un solo uso (OTP)
- 2) el DNI digital, viendo su evolución desde el DNIE hasta el DNI 3.0.

1.3.1. Dispositivos OTP

Las siglas OTP provienen del inglés *one time password*, es decir, un dispositivo capaz de facilitar una contraseña que tan solo podrá ser utilizada una sola vez. Este mecanismo de autenticación siempre se complementa con otro mecanismo previo de identificación o autenticación, por lo que el OTP se utiliza en autenticaciones 2FA (doble factor).

El uso de OTP minimiza muchos de los riesgos que hemos comentado anteriormente sobre el uso tradicional de contraseñas, como, por ejemplo, evitar ataques de fuerza bruta, ya que la contraseña varía constantemente. De esta forma, un atacante que se haga con el valor de la contraseña de un solo uso no podrá volver a utilizar el mismo valor para sucesivas autenticaciones.

En la actualidad podemos encontrar múltiples implementaciones de OTP mediante dispositivos como pueden ser los siguientes:

1) **Tokens físicos** específicos que implementan el protocolo OTP. Normalmente, mediante la pulsación de un botón, generan la contraseña de un solo uso que se muestra en una pequeña pantalla digital.

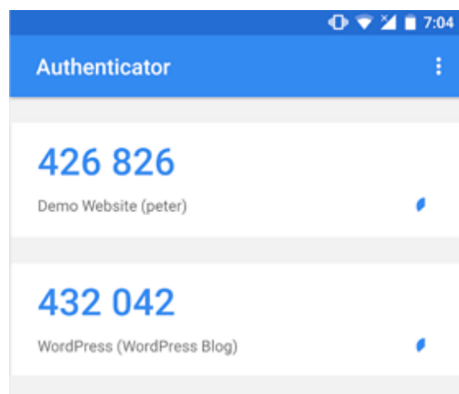
Figura 6. Token físico



Fuente: www.microcosm.com/it-security-hardware/oath-otp-authentication-tokens

2) **Aplicaciones software** que implementan el protocolo OTP que se instalan en el teléfono móvil o tableta. Esto permite no tener que transportar el *token* OTP adicional y utilizar uno de los dispositivos portátiles más comunes en la sociedad actual. Un ejemplo de aplicación OTP es Google Authenticator.

Figura 7. Google Authenticator



Los dos protocolos más utilizados para la implementación de OTP son:

1) **HOTP**: protocolo de OTP basado en eventos. Este protocolo se basa en el algoritmo de firma HMAC (o firma por función *hash*).

- El *token* almacena un identificador único que actúa como clave simétrica para aplicar HMAC. El *token* también incluye un contador interno dinámico. Ambos valores también son conocidos por el servidor.
- El *token* genera una firma HMAC sobre el valor del contador utilizando la clave simétrica única. El contador se incrementa en uno cada vez que se pulsa el botón.
- Como una firma HMAC incluye un número elevado de dígitos, lo que penalizaría la experiencia de usuario a la hora de introducir la contraseña de un solo uso, se aplica un algoritmo para obtener un valor decimal de 6, 8 o 10 dígitos a partir de una parte de la firma HMAC. Este valor decimal será la contraseña de un solo uso.
- El servidor validará la contraseña de un solo uso verificando la firma digital HMAC, ya que conoce la clave simétrica del *token* y la numeración del contador actual en cada validación. De esta forma, cliente y servidor son capaces de generar la misma firma sobre el contador y comprobar que la contraseña de un solo uso es válida.
- Los detalles del algoritmo utilizado para el cálculo de la contraseña de un solo uso se pueden encontrar en la RFC 4226, concretamente en el apartado 5.4, «Example of HOTP Computation for Digit = 6».

2) **TOTP**: protocolo de OTP basado en tiempo. Implementa el mismo protocolo comentado en HOTP, pero el factor dinámico del *token* no es un contador, sino que es la unidad de tiempo que irá variando (también llamado *timestep*). Esto garantiza que cada cierto tiempo, la contraseña de un solo uso variará.

1.3.2. DNI electrónico

El DNI electrónico es una tarjeta inteligente emitida por la **Dirección General de Policía** del Ministerio de Interior de España. El DNI permite las siguientes acciones:

- Acreditar electrónicamente y de forma segura la identidad de la persona.
- Firmar digitalmente documentos electrónicos, otorgándoles una validez jurídica equivalente a la que les proporciona la firma manuscrita.

Este dispositivo fue inicialmente creado en el 2006 y se conocía por el nombre de **DNLe**. Contiene la siguiente información:

- datos de filiación del ciudadano
- datos biométricos (modelo dactilar, foto y firma manuscrita)
- dos pares de claves RSA con sus respectivos certificados digitales, uno de autenticación y otro de firma electrónica. Las claves RSA se generan y almacenan en el chip criptográfico del DNLe, lo que imposibilita su extracción, ya que solo podrá utilizarse mediante la generación de firmas en el propio dispositivo criptográfico. Los certificados son generados por la CA de la DGT.

Para poder usar el DNLe, al igual que con otras tarjetas inteligentes, es necesario un lector de tarjetas, por ejemplo, el que muestra en la figura siguiente.

Figura 8. DNI Electrónico



Fuente: propia

Protección del DNLe

El DNLe mantiene el material criptográfico sensible siempre en su interior y protegiendo su uso gracias a un control de acceso mediante un número de identificación personal que solo el usuario conoce.

La información en el chip está distribuida en tres zonas con diferentes niveles de seguridad y condiciones de acceso:

1) **Zona pública.** La lectura de esta zona es accesible sin restricciones. Contiene, entre otros, el certificado del emisor y unas claves para cifrar el intercambio de información entre el chip y el dispositivo de lectura. Estas claves están certificadas mediante un certificado de componente.

2) **Zona privada.** La lectura de esta zona está permitida al ciudadano mediante la clave personal de acceso o PIN. Contiene un **certificado de autenticación** (que tiene, como finalidad, garantizar electrónicamente la identidad del ciudadano al realizar una transacción telemática) y un **certificado de firma**.

3) **Zona de seguridad.** Los ciudadanos pueden acceder a esta zona en los puntos de actualización del DNI electrónico. Contiene los datos impresos en el soporte físico del DNI, la fotografía y la firma escaneada.

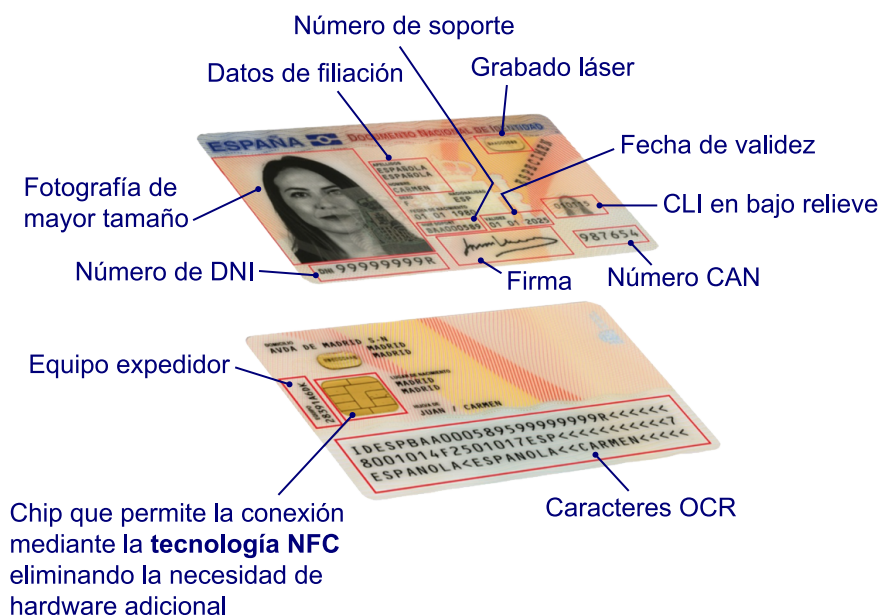
No obstante, esta versión del DNLe que apareció en el 2006 demostró tener ciertos inconvenientes que provocaron que no fuese adoptado en la medida deseada por la ciudadanía debido a sus problemas de usabilidad. La necesidad de utilizar un lector de tarjetas inteligentes provoca problemas de compatibilidad con el amplio abanico de sistemas operativos, navegadores de usuario, portabilidad entre diferentes sistemas personales (hogar, trabajo, etc.).

Debido a estos problemas, el DNLe se modernizó en 2015 con la aparición del DNI 3.0. La principal novedad es la incorporación de tecnología con interfaz dual, que permite la conexión mediante contacto (hardware específico), pero también de **forma inalámbrica** mediante la tecnología NFC (*near field communication*). Esta tecnología está presente en la mayoría de los dispositivos móviles actuales (teléfonos, tabletas), lo que permite una mayor usabilidad sin requerir de un hardware específico que deba estar instalado en el sistema.

Certificado de componente

El certificado de componente permite la autenticación mutua de dispositivos tal y como se describe en el estándar CWA-14890.

Figura 9. Especificaciones técnicas y de seguridad del DNI 3.0



Los certificados electrónicos del DNI 3.0 pueden utilizarse para:

- Autenticar la identidad de un ciudadano español mediante su certificado de autenticación. Las administraciones públicas permiten realizar trámites, como realizar gestiones con la Dirección General de Policía (consulta de los puntos del carné de conducir, etc.), presentar la declaración de la renta digitalmente ante la AEAT (Agencia Estatal de Administración Tributaria) o realizar gestiones con la Seguridad Social (obtención de fe de vida laboral, etc.)
- Firmar un documento electrónicamente para que el receptor de este pueda comprobar la integridad y la identidad del firmante del documento (identificación y no repudio). Esta característica es viable mediante su certificado de firma digital. Representa un paso adelante en la digitalización de la Administración pública, ya que evita la gestión de documentos físicos y permite que estos tengan la misma validez legal que una firma manuscrita. Un claro ejemplo es la **facturación electrónica**, cuando el Gobierno español (impulsado por el Ministerio de Hacienda) aprueba el Real decreto 1496/2003, por el que se regulan las obligaciones de facturación exigidas actualmente por la Administración pública, de forma que se establece la factura electrónica como documento tributario, en formato electrónico, con el mismo valor legal que la factura en papel. El gobierno fue más allá y decidió que, desde el 15 de enero de 2015, todas las facturas dirigidas a las administraciones públicas debían ser electrónicas, y el DNI 3.0 es uno de los mecanismos reconocidos legalmente.

1.4. Biometría

La biometría viene a significar algo así como «medir» los rasgos «biológicos» de un individuo.

La biometría es la aplicación de las matemáticas y la ciencia de la computación para identificar individuos de acuerdo con sus características o rasgos físicos.

Esta tecnología hace años que aparece como habitual sistema de autenticación en la literatura y películas de fantasía y ciencia ficción. De todos modos, el análisis del iris, la forma de la mano, incluso la manera de andar, etc., ya juegan un papel importante en sistemas de control de acceso reales. Además, es conocido que el uso de las huellas dactilares para la identificación de un individuo es ya un sistema clásico en organismos policiales.

En un sistema biométrico el individuo debe en primer lugar registrarse. Entonces una o más características físicas o de conducta son registradas por un sistema de información. Para la identificación del individuo, el sistema de información recoge las características del individuo que quiere identificarse para hacer una comprobación en su base de datos. Si la información recogida no coincide con ninguno de los individuos registrados, se deniega el acceso.

Si el número de individuos registrados es muy elevado, el sistema no buscará entre todos los individuos de su base de datos, ya que podría llegar a ser costoso y potenciador de errores. El individuo que quiere identificarse lo hace mediante un código (o cualquier otro identificador), mientras que el sistema biométrico comprueba que las características físicas recogidas para el individuo con el identificador concreto coinciden con las almacenadas. En este caso, el sistema biométrico realiza una autenticación de la identificación.

No obstante, hay distintos problemas a los que hacer frente. El primero es el de la recogida de características: los sistemas deben obviar ruidos, imperfecciones o distintos matices que los sistemas captadores y sensores recogen a cada acceso de un individuo. En segundo lugar, se deben minimizar las tasas de errores del sistema de identificación: no se debe permitir la autenticación de un individuo no registrado o no válido y, al contrario, no se debe denegar la correcta autenticación de un individuo registrado o válido. En este sentido, la tasa de falso positivo⁷ y la de falso negativo⁸ miden el buen funcionamiento y rendimiento del sistema biométrico.

⁽⁷⁾En inglés, *false acceptance*.

⁽⁸⁾En inglés, *false nonmatch rate*.

A continuación, enumeramos los rasgos biométricos más utilizados y comentamos aspectos sobre su calidad y uso:

- **Huellas dactilares.** El uso de las huellas dactilares como medio de identificación es de alta fiabilidad. Tiene buena aceptación y popularidad.
- **Ojo.** La identificación de un individuo mediante el análisis del iris tiene una fiabilidad muy alta. El problema es la facilidad de uso. El análisis de la retina para identificar al individuo es más complejo todavía.
- **Forma de la mano.** Este sistema está bastante extendido, pero quizás presenta un poco menos de fiabilidad que los anteriores. Este sistema es susceptible de padecer ataques, puesto que no resultaría difícil recrear la forma de una mano usando un molde.
- **Cara.** El análisis de la cara, ya sea en 2D o 3D, es un buen medio para identificar a un individuo. Aun así, siempre es preferible un estudio 3D, ya que se mejoran los resultados con respecto al mero estudio de una imagen 2D y se dificulta el éxito de ataques. La desventaja de los equipos 2D es que el sistema no distingue si lo que está capturando es realmente un rostro o una fotografía de un rostro.

- **Venas del dedo o la mano.** El estudio vascular de los dedos o de la mano proporciona alta fiabilidad, además no es muy complejo su análisis.
- **Voz.** Este sistema presenta bastante fiabilidad, pero también es susceptible a los ataques. Además, este sistema padece de poca estabilidad, con lo cual deberían ser varias las tomas de voz analizadas para reducir la tasa de errores.

Claramente, son varias las características biométricas que pueden usarse para identificar o autenticar. Estas pueden usarse individualmente, o bien en combinación entre ellas, o bien procediendo a la autenticación mediante información adicional, como podría ser una contraseña. La figura siguiente muestra un lector de huella digital para ayudar a la identificación en un ordenador portátil.

Figura 10. Lector de huellas digitales en un portátil Apple MacBook Air



Fuente: www.teknofilo.com/wp-content/uploads/2018/11/Analisis-MacBook-Air-Teknofilo-10.jpg

1.5. Legalidad en identificación y firma electrónica

La era de la digitalización ha permitido que las personas puedan realizar un gran número de transacciones por medios digitales: servicios financieros, intercambio de documentación en el ámbito empresarial, acceso a trámites cotidianos con las administraciones públicas, etc. Este hecho facilita enormemente poder realizar estos trámites sin necesidad de personarse físicamente.

En el ámbito de la identificación, como se ha visto anteriormente, la firma electrónica permite además garantizar la integridad de un documento y el no repudio por parte del firmante.

Al eliminar la presencialidad en la ejecución de procesos que implica la identificación de personas físicas, o en representación de una empresa, aparece la necesidad de aplicar nuevos marcos legales que permitan garantizar la identidad de las personas remotamente cubriendo las mismas características legales.

En este apartado se revisará el marco legal aplicable actualmente a nivel europeo para la identificación electrónica y de servicios de confianza (eIDAS). Bajo este marco regulatorio se analizará un caso de uso de aplicación directa, como es la facturación electrónica en España. El apartado finalizará con la introducción del Cloud Signature Consortium, bajo el que la industria trata de estandarizar los aspectos técnicos para la firma digital en entornos *cloud*.

1.5.1. eIDAS

eIDAS son las siglas en inglés de *electronic identification, authentication and trust services*. Se trata del nombre de la regulación europea N.º 910/2014, aplicable desde el 1 de julio de 2016, la cual deroga la anterior directiva de firmas 1999/93/CE, de 13 diciembre de 1999. Este reglamento es de vital importancia, ya que establece el marco jurídico de ejecución en todos los Estados miembros de la UE, lo que significa que los servicios públicos de los Estados miembros deben reconocer los sistemas nacionales de identificación electrónica (eID).

Los ciudadanos y las empresas pueden utilizar su identidad digital de su país nativo cuando acceden a servicios públicos dentro de otros Estados miembros de la UE que también utilicen identidades electrónicas. Este reglamento define las condiciones en las que los Estados miembros reconocerán la identificación electrónica de los usuarios.

Además, este reglamento especifica estándares para firmas electrónicas, sellos de tiempo, sellos electrónicos y otras pruebas de autenticación, incluida la certificación electrónica y los servicios de entrega registrada, que otorgan a esas transacciones electrónicas el mismo estatus legal que si se realizaran en papel.

Los tipos de firma que ya se establecieron en la directiva 1999/93/CE y que han sido actualizadas en eIDAS son:

- La **firma electrónica simple**. Conjunto de datos en forma electrónica, consignados junto a otros o asociados con ellos, que pueden ser utilizados como medio de identificación del firmante. Este tipo de firma no tiene efectos jurídicos totales. No es suficientemente segura, ya que no se garantiza que haya sido creada por el supuesto firmante; puede tratarse de una firma reproducible por un usuario malintencionado.
- La **firma electrónica avanzada**. Permite identificar al firmante y detectar cualquier cambio posterior de los datos firmados; está vinculada al firmante de manera única y a los datos a los que se refiere.
- La **firma electrónica cualificada**. Realizada con un certificado cualificado de firma, incluye todas las características de las firmas electrónicas avanzadas, pero añadiendo la misma robustez jurídica que la tradicional firma manuscrita. Para realizar una firma cualificada debe utilizarse un certifi-

cado digital cualificado emitido por una entidad QTSP (*qualified trust service provider*) y la firma debe realizarse en un dispositivo seguro de firma (QSCD, *qualified signature creation device*).

Los servicios de confianza cubiertos por eIDAS incluyen:

- firmas electrónicas avanzadas y cualificadas asociadas a una persona física o jurídica
- sellos electrónicos avanzados y cualificados asociados a una persona jurídica
- validación para sellos y firmas electrónicas cualificadas
- conservación de firmas y sellos electrónicos cualificados
- sellos de tiempo
- servicios de entrega electrónica (no repudio)
- autenticación de sitios web

Cabe destacar que eIDAS viene acompañada de un conjunto de normativas técnicas para la implementación de dispositivos cualificados de firma (QSCD) **con custodia de claves privadas en el *cloud***. Hasta la normativa actual, los dispositivos QSCD (como el DNLe o DNI 3.0 en España) no podían custodiar las claves privadas en entornos de servidor.

El estándar CEN EN 419 241 (*trustworthy systems supporting server signing*) define los requisitos de seguridad que debe implementar un proveedor cualificado de firma (QTSP). También se define el perfil de protección necesario para certificar un dispositivo cualificado de creación de firmas (QSCD), cuyas claves privadas son custodiadas en un servidor bajo el control exclusivo del usuario, es decir, que solo podrá activarse la clave privada de firma si el usuario ha dado su consentimiento explícito.

1.5.2. Cloud Signature Consortium

La aparición de eIDAS establece unos requisitos funcionales rigurosos para la implementación de firmas seguras, pero deja abierta la puerta a múltiples soluciones técnicas, lo que dificulta la **interoperabilidad** de las diferentes empresas que desean realizar transacciones electrónicas seguras entre los países miembros de la UE.

El consorcio CSC, *Cloud Signature Consortium*, está formado por un gran número de empresas tecnológicas líderes (como Adobe, DocuSign o Entrust) comprometidas a construir un nuevo estándar para firmas digitales basadas en la

nube que cumplirá con las regulaciones de firma electrónica, entre ellas, eIDAS. Se espera que su impacto sea global a medida que la demanda de soluciones digitales de alta seguridad siga aumentando.

El objetivo es proporcionar una especificación técnica común que hará que las soluciones sean interoperables y adecuadas para una adopción uniforme en el mercado global.

CSC ha publicado la definición de una arquitectura común y protocolos de comunicación destinados a crear una API estándar para integrar los componentes esenciales de una solución de firma remota establecida entre diferentes proveedores de servicios y consumidores. La firma remota habilita la capacidad de invocar servicios de custodia de claves y firma digital mediante servicios REST basados en HTTP en contraposición a realizar firmas locales con dispositivos conectados a la computadora del usuario, como puede ser el DNIE.

La actual especificación técnica incluye detalles de implementación concretos para permitir funcionalidades como:

- identificación y autorización de las aplicaciones y los usuarios bajo el estándar OAuth2
- gestión de las identidades de firma remotas de un usuario
- capacidad de firma cualificada sobre un conjunto de datos utilizando una identidad bajo el control exclusivo del usuario

2. Ciclo de vida de la identidad digital

Una identidad digital pasa por tres pasos básicos en su ciclo de vida: la creación, el uso y la desaparición o baja. En este apartado estudiaremos aspectos relacionados con el alta, el uso y la baja de las identidades digitales, en concreto, las contraseñas y los certificados.

2.1. Alta de usuarios

El alta de un usuario es el procedimiento previo a que este pueda usar un servicio o bien acceder a un sistema. Existen dos formas mediante las cuales un usuario puede darse de alta en un sistema:

1) **De forma presencial.** El individuo acude al gestor de identidades del sistema o del servicio (por ejemplo, al administrador de los equipos informáticos de una empresa) y este le proporciona la información necesaria para usar el servicio. En este caso el gestor de identidades ha identificado y autenticado al usuario de forma presencial. La presencialidad es importante en aquellos sistemas o servicios con potenciales riesgos.

Importancia de la presencialidad

Obtener un certificado digital o una tarjeta de coordenadas para operar con una entidad financiera pueden ser un par de situaciones en las que se requiera presencialidad.

2) **De forma no presencial.** En este caso el individuo elige (o se le asigna) un nombre de usuario y también una contraseña u otra información para su autenticación. En este caso, útil y habitual en aquellas situaciones que no haya grandes riesgos, será necesario realizar una serie de comprobaciones para mejorar la seguridad del proceso de alta de usuario.

2.1.1. Confirmación no presencial de la identidad

En la forma presencial, quien da de alta el identificador y demás información de autenticación precisará de la verificación visual de que el solicitante es quien dice ser. Sin embargo, tal y como se ha apuntado, en los sistemas no presenciales deben tomarse una serie de medidas para evitar situaciones como la suplantación de identidad o el acceso indebido a los sistemas.

Supongamos que un usuario quiere darse de alta en un servicio telemático para el cual será necesario introducir una contraseña como sistema de autenticación. El usuario introduce su identificador (del cual se comprobará que no haya otro igual en el sistema) y una contraseña. Se pueden usar estas herramientas para mejorar el alta de usuario:

- **Correo electrónico.** Se puede pedir al usuario que introduzca una dirección de correo electrónico. En esta dirección, se recibirá un correo que contendrá un enlace a una página que activa automáticamente la cuenta de usuario recién creada. Ahora bien, supongamos el caso de que el servicio es una red social. Al no haber comprobación presencial, se podría usar una dirección de correo electrónico propia (con lo cual la activación tendría éxito), pero al mismo tiempo, estar creando un identificador para rellenar el perfil de red social de otro individuo.
- **Teléfono móvil.** Otro sistema podría consistir en pedir un número de teléfono móvil, al cual el servicio mandará un código de activación. Claramente, como en el caso del correo electrónico, no se evita la posibilidad de fraude. No obstante, con la legislación actual se puede identificar al propietario del número del teléfono móvil.
- **Confirmación por datos.** Si el sistema telemático se corresponde con una entidad que ha mantenido relación con el usuario previamente, se pueden pedir datos para comprobar que la identidad del solicitante se corresponde con el individuo. Podría ser el caso de crear un acceso a la oficina virtual de una compañía eléctrica: se podría pedir, por ejemplo, una cantidad determinada de alguna de las facturas emitidas con anterioridad.

Autenticación por móvil

El medio de autenticación por el teléfono móvil es habitual para la confirmación de operaciones de compra en internet.

Finalmente, en muchos casos se pretende evitar el uso indebido del servicio (por ejemplo, un servicio de correo electrónico, un blog o un foro), o bien se quiere proteger el sistema ante bloqueo del servicio. En el primer caso, un programa podría automáticamente darse de alta en múltiples servicios para inundarlos de publicidad. En el segundo, el programa iría realizando peticiones automáticas y creando usuarios hasta colapsar el sistema. Para evitar que un programa use formularios pensados para que los rellene un humano, se usan los **captchas**.

Captcha

Captcha es el acrónimo de *completely automated public Turing test to tell computers and humans apart*; en castellano, 'prueba de Turing pública y automática para diferenciar máquinas y humanos'.

Un captcha es una prueba que en principio solo puede ser resuelta por humanos y no por programas, y cuyo objetivo es diferenciar a un humano de un programa.

La típica prueba es que el usuario debe introducir por teclado una palabra o conjunto de caracteres que se exponen por medio de una imagen distorsionada, borrosa, con ruido, etc., es decir, con cualquiera de las características que pueda dificultar la lectura automática por parte de un programa, pero no para un humano.

Figura 11. Ejemplo de captcha



Los mecanismos anteriores tratan de validar la identidad del usuario mediante pruebas paralelas que permitan al usuario pasar varias pruebas para la mejora de la experiencia y seguridad. Aun así, ciertos servicios en línea, como procesos de alta en la Administración pública, pueden requerir la **validación real del usuario hecha en línea, de una forma parecida a como se haría presencialmente**, es decir, realizando comprobaciones sobre el documento de identidad en tiempo real con el usuario. Para solucionar este caso de uso, existen servicios por internet de verificación de la identidad que hacen conectar al usuario en línea con un operador haciendo uso de la *webcam* y el micrófono del dispositivo. Mediante este proceso, el operador puede solicitar al usuario que muestre su documento de identidad ante la cámara web, así como varios perfiles de su rostro para validar la veracidad tanto del documento como que se trata de la persona que dice ser. Este tipo de servicio mejora exponencialmente la accesibilidad y la experiencia de usuario en el registro de identidades que requieren un nivel alto de protección en la identificación de usuarios.

2.2. Procedimiento de autenticación

Cuando un usuario se ha dado de alta en el servicio, ya está en disposición de usarlo. Es entonces cuando, concretamente, ya puede autenticarse en el servicio. Por ejemplo, ya puede usar su perfil de red social, o bien puede acceder a hacer un trámite con la Administración.

El sistema deberá tener en cuenta que el usuario se ha autenticado y se encuentra en una **sesión activa**. Los distintos sistemas operativos tienen implementado el control de los usuarios que están activos, pero esto no ocurre en las aplicaciones basadas en la web.

Trasladar directamente a las páginas web el concepto de sesión no es posible, puesto que el protocolo HTTP⁹ trata las peticiones que hace el usuario de forma independiente. Para poder implementar el concepto de sesión en la tecnología de páginas web es necesario usar una *cookie* de sesión.

⁽⁹⁾HTTP es la sigla de *hypertext transfer protocol*.

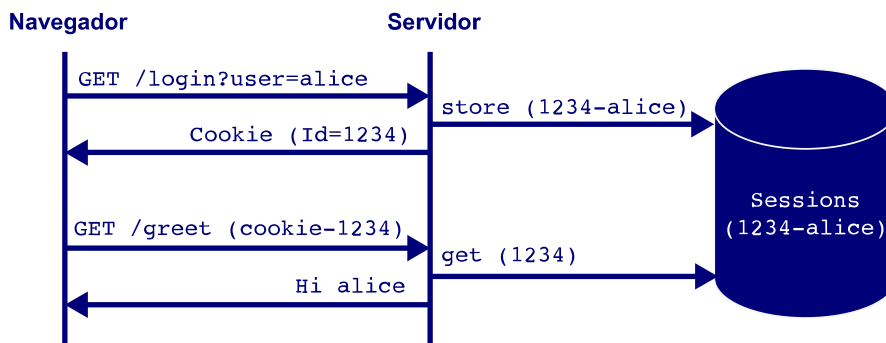
Una *cookie* es un fichero de texto que el servidor web guarda en la máquina cliente. Son los únicos ficheros que, por defecto, se pueden depositar en el equipo cliente sin que su usuario sea consciente.

Sesiones sin cookies

Pueden implementarse sesiones sin usar *cookies*: en este caso el identificador de sesión es un parámetro más de la dirección web.

Las *cookies* se usan para guardar información variada sobre el cliente, por ejemplo, se pueden guardar ciertas preferencias de aspecto de un sitio web que tiene el usuario. Mediante las *cookies de sesión*, se pueden manejar sesiones de usuarios autenticados en páginas web: cuando el usuario se identifica correctamente, se le asigna un número de sesión (una cadena de bits larga y aleatoria). Este número de sesión suele guardarse en una *cookie* en el ordenador cliente. Así pues, el servidor es capaz de asociar al cliente con una determinada sesión.

Figura 12. Cookies de sesión



Dentro de una sesión hay datos cuyo valor debe estar disponible durante toda la sesión: son las llamadas *variables de sesión*. Un lenguaje como PHP dispone de herramientas para empezar una sesión (`session_start()`), terminar una sesión (`session_destroy()`), así como herramientas para controlar las variables de sesión.

En este mismo contexto, el uso de *cookies* que guardan información sobre los hábitos de navegación de los usuarios ha estado supeditado a regulaciones y normativas. Desde la aparición de la normativa *ePrivacy* de la Unión Europea en el 2002 y los cambios sufridos por la aplicación del Reglamento General de Protección de Datos (RGPD) en el 2018, el uso de *cookies* para la navegación de sitios web incluya ciertas restricciones de obligado cumplimiento, como pueden ser las siguientes:

- Se debe informar de forma clara y entendible sobre el uso de *cookies* en el sitio web.
- El usuario debe dar consentimiento explícito sobre el uso de *cookies*. En caso de que el usuario no haya dado el consentimiento, el uso de *cookies* estará prohibido.
- El consentimiento de uso de *cookies* nunca debe ser una precondition para el uso de otros servicios del sitio web.

2.2.1. Autenticación mediante contraseña

En el apartado 1.1. se revisó en detalle el mecanismo de autenticación mediante contraseña, donde se presentaron las vulnerabilidades que presenta su uso, así como el mecanismo de protección para guardar las contraseñas en un servidor y minimizar el riesgo de exposición de estas en caso de robo de los datos del repositorio de almacenamiento de contraseñas. A continuación, se exponen algunos detalles importantes para tener en cuenta en la etapa de transporte de la contraseña hasta el servidor, donde deberá ser validada con las mayores garantías de seguridad.

Durante el procedimiento de validación de la identidad mediante contraseña, el usuario manda una contraseña al servicio de autenticación, el cual aplicará los mecanismos pertinentes. Cuando el usuario introduce la contraseña en la aplicación Cliente, esta no puede transmitirse precalculando la función *hash* sobre ella, ya que en el servidor se almacenó el valor de aplicar la función de *hash* a la concatenación de un valor *random* (*salt*) y la propia contraseña. La aplicación Cliente no conoce el valor del *salt*. La contraseña se deberá transmitir al servidor en su formato original. Para evitar la transferencia de la contraseña en claro para que el servidor pueda validarla, se debe incluir un protocolo que aplique autenticación, integridad y confidencialidad al canal de transporte. Veamos un ejemplo para la autenticación con contraseña en el protocolo de comunicación HTTP.

Ved también

Se pueden revisar los mecanismos del servicio de autenticación en el apartado 1.1.2. de este módulo.

Ejemplo de autenticación con contraseña en el protocolo de comunicación HTTP

En HTTP se utiliza el mecanismo *Basic* (RFC 7617) para transmitir en la cabecera «Authorization» el nombre de usuario y la contraseña codificados en base64. Este algoritmo de codificación no aporta confidencialidad. Para utilizar este mecanismo de autenticación es obligatorio incluir un protocolo de protección del canal de comunicación, como puede ser TLS. De esta forma, todos los datos que se transmiten entre cliente y servidor estarán autenticados, protegidos en integridad y serán confidenciales.

Véase el siguiente ejemplo. Se incluye la siguiente cabecera HTTP:

```
Authorization: Basic QWxhZGRpbjpvcGVuIHNlc2FtZQ==
```

Al decodificar el valor en base64 podemos observar que se trata del siguiente valor: Aladdin:open sesame. Coincide con el nombre de usuario y la contraseña del usuario. Este hecho deja en evidencia nuevamente la necesidad imperiosa de transmitir el mensaje HTTP mediante un canal securizado con TLS.

Otro problema importante para tener en cuenta a la hora de autenticarse mediante contraseña: un atacante podría tener instalado un programa en el equipo del cliente que registrara todas las pulsaciones de teclado para luego mandarlas al atacante y proceder a su análisis.

Un *keylogger* es un sistema, generalmente software, cuyo objetivo es registrar todo lo que teclea el usuario del sistema donde está instalado, con fines de usurpación de contraseñas.

En general se trata de software, aunque también los hay en forma de dispositivo hardware, los cuales se pueden identificar fácilmente mediante una inspección visual. Para defenderse de los *keyloggers*, va siendo habitual pedir al usuario que utilice el ratón en lugar del teclado para introducir una contraseña, tal como se ve en la figura siguiente. En este caso, los caracteres para escribir la contraseña irán cambiando de posición a cada acceso de autenticación, con lo cual es más complejo pensar en un *mouselogger*. En este caso, el atacante necesita capturar la pantalla del usuario para obtener la información (*screenlogger*).

Figura 13. Entrada de PIN mediante el ratón para evitar posibles *keyloggers*



2.2.2. Autenticación mediante certificados electrónicos

Los protocolos y especificaciones SSL/TLS/WTLS⁽¹⁰⁾ protegen la capa del transporte de la información entre clientes y servidores web. Su uso, además, está extendido al envío y recepción de correo electrónico y, en general, a todas las aplicaciones que precisen de seguridad. Básicamente proporcionan:

- confidencialidad entre cliente y servidor (por ejemplo, para enviar información, como números de tarjeta de crédito o contraseñas)
- autenticidad del servidor (usando un certificado electrónico de servidor como método de autenticación)
- integridad de la información

Además, estos sistemas permiten la identificación de un cliente mediante su certificado. Al tratarse de especificaciones y protocolos muy parecidos, se tiende a hablar de ellos como los *protocolos SSL o TLS*.

Cuando nos conectamos a un sitio web seguro (identificado mediante HTTPS⁽¹¹⁾), tiene lugar una comunicación entre cliente y servidor destinada a crear un canal de comunicación seguro.

⁽¹⁰⁾SSL es la sigla de *secure socket layer*; TLS, de *transport layer security*; y WTLS, de *wireless transport layer security*.

⁽¹¹⁾HTTPS es la sigla de *hypertext transfer protocol over secure socket layer*.

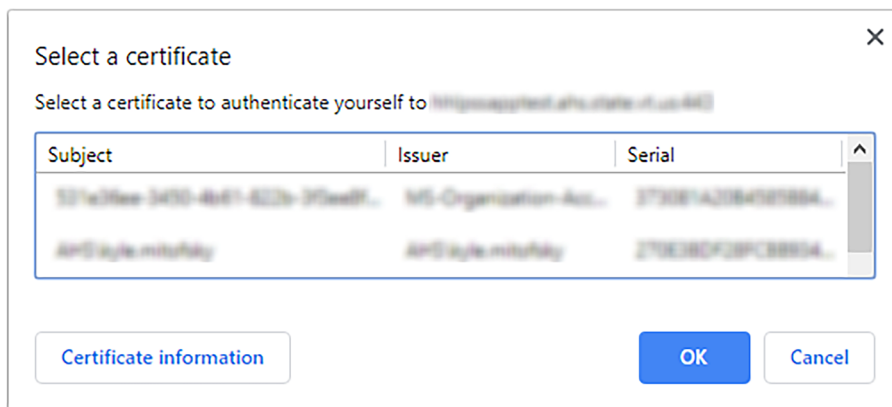
Ejemplo de comunicación entre cliente y servidor

En este ejemplo se resumen los mensajes que se transmiten cuando un cliente se conecta a un servicio HTTPS autenticado mediante un certificado de servidor:

- *Hello request.* El servidor manda este mensaje al cliente (el navegador web) para iniciar la securización.
- *Client hello.* El cliente responde, dando una serie de información, como por ejemplo qué algoritmos criptográficos soporta (el servidor tendrá que acomodarse ante una variedad de software cliente con distintas versiones y sistemas operativos).
- *Server hello.* El servidor responde y especifica qué combinación de algoritmos criptográficos se usará.
- *Certificate.* El servidor manda el certificado de servidor que incluye una referencia al emisor, con la cual el cliente podrá decidir si confía o no directamente en el certificado.
- *Server hello done.* A partir de este mensaje se intercambian las claves criptográficas y empieza la comunicación segura.

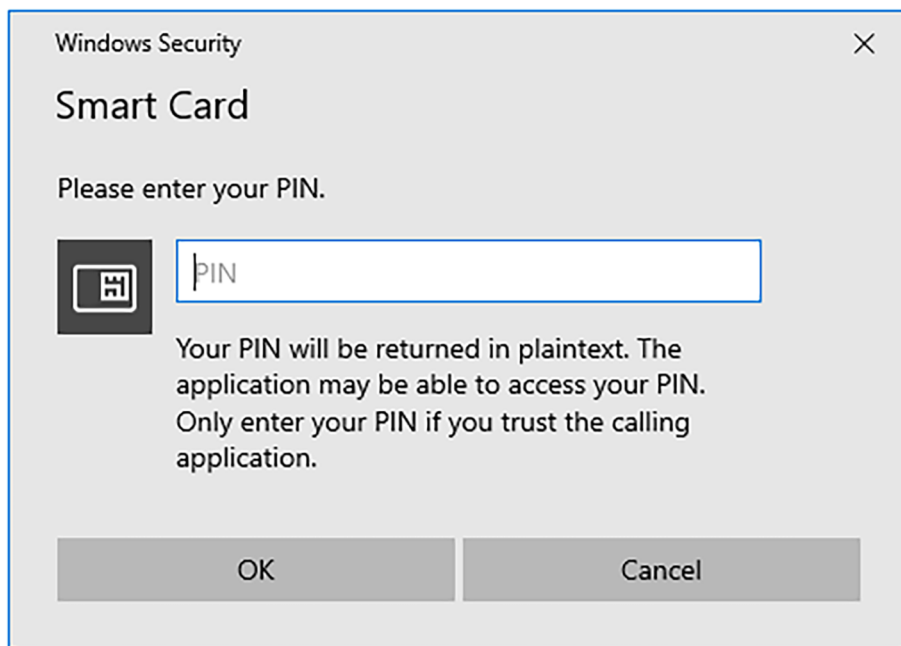
Un caso un tanto distinto es cuando el servidor requiere que el cliente se valide usando un **certificado de cliente** (el caso, por ejemplo, de la validación mediante el DNIE). En el caso de TLS, el servidor mandará, antes del *Server hello done*, el mensaje *Certificate request*. Este mensaje contiene una lista de los posibles tipos de certificado que el servidor puede admitir, por orden de preferencia. También manda una lista de autoridades de certificación. Así pues, el navegador carga el certificado correspondiente (en caso de haber varios certificados de cliente, el sistema pide elegir uno de ellos), tal como se ve en la figura siguiente.

Figura 14. *Certificate request*



Los certificados de cliente (junto con sus claves privadas) estarán almacenados en un repositorio seguro, como puede ser el propio repositorio del sistema operativo, o en un dispositivo cualificado de creación de firmas (QSCD), como puede ser el DNI 3.0. Al seleccionar un certificado de cliente de la lista que presenta el navegador, el repositorio solicitará los mecanismos de identificación adicionales que tenga establecidos. Por ejemplo, en el caso del DNIE, el usuario deberá demostrar que es el poseedor mediante la introducción del código o contraseña correspondiente.

Figura 15. Cuadro de diálogo para introducir la clave que permite usar el DNle



Si la validación ha tenido éxito, se procederá a mandar el certificado mediante el mensaje *Certificate*.

2.2.3. Autenticación *single sign-on*

Al principio de la llegada de internet, los usuarios disponían de pocos servicios ante los que autenticarse. Hoy en día, son millares los sitios web que requieren de una autenticación del usuario para que este los pueda usar. Desde la cuenta de correo, la red social, el servidor de vídeos o el espacio de comentarios de la prensa, etc. Asimismo, muchas empresas y organizaciones disponen de múltiples servicios propios o internos basados en la web.

Está claro que en ambos escenarios los usuarios deben recordar múltiples nombres y sus respectivas contraseñas para poder utilizar todos los servicios a los que están suscritos. Evidentemente, usar siempre la misma contraseña para todos los servicios plantea un problema: si un atacante obtiene la contraseña puede usarla de forma deshonesta en todos los servicios.

Los sistemas *single sign-on* permiten el acceso a varios servicios a partir de un único acto de autenticación inicial.

Para solucionar el hecho de que, dentro de una organización o un grupo de aplicaciones basado en la web, se tengan que usar múltiples nombres de usuario y contraseñas, existe el procedimiento *single sign-on*.

Ejemplo de sistema *single sign-on*

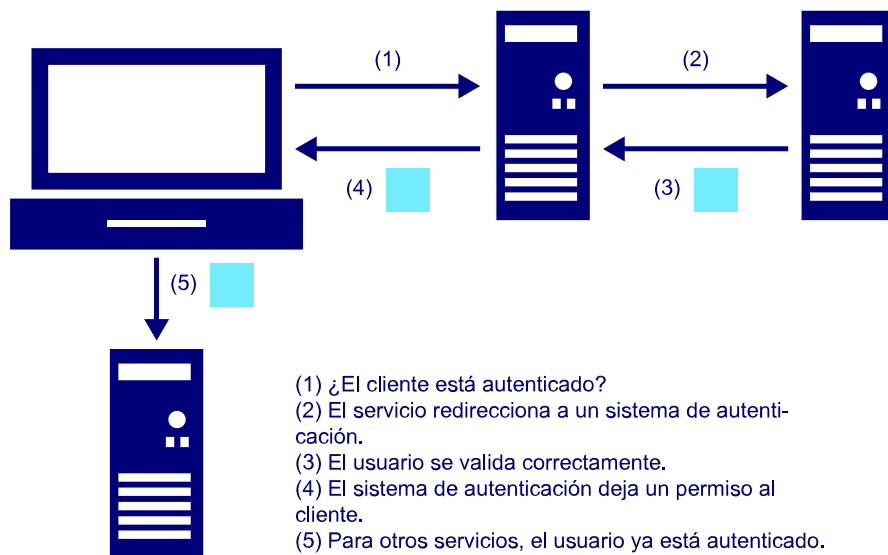
Una compañía ofrece un correo electrónico, un disco virtual, un calendario y un sistema de elaboración cooperativa de documentos por medio de la web. Cuando el usuario quie-

Problema de los sistemas *single sign-on*

Obviamente, los sistemas *single sign-on* también permiten a un atacante acceder a múltiples servicios conociendo una única contraseña del usuario.

re usar, por ejemplo, el calendario, debe autenticarse ante el sistema. Con esto, al no estar autenticado, es redirigido a un sistema autenticador. Si el usuario se valida correctamente, ya puede usar el calendario. Si el usuario ahora quiere trabajar con un documento en línea, no debe volver a autenticarse. Probablemente, el sistema de autenticación le habrá dejado en el equipo una *cookie* como prueba de que el usuario se ha validado. Esta *cookie* tendrá un periodo de validez a partir del cual la sesión habrá caducado y el usuario tendrá que autenticarse de nuevo. La figura 16 muestra este procedimiento.

Figura 16. Procedimiento resumido de autenticación *single sign-on*



2.3. Baja de usuarios

El ciclo de vida de una identidad digital termina con un procedimiento de baja. Todo proceso de gestión de identidades debe contemplar cómo se realiza este trámite. A continuación, comentamos algunos aspectos referentes a la baja de contraseñas y certificados electrónicos.

2.3.1. Baja de contraseñas

Cuando un individuo ya no puede (o no quiere) usar un servicio telemático, debe (o puede) darse de baja. En los sistemas gestionados por administradores, este procedimiento debe hacerse cuando se notifique el cese del individuo. Claramente, un individuo que, por ejemplo, ya no trabaje en una empresa, no debería poder acceder a sus servicios telemáticos, como por ejemplo el correo electrónico o la intranet. Normalmente, puede definirse un breve periodo durante el cual el usuario todavía estará activo en todos o algunos de los servicios. Por ejemplo, no puede acceder a la intranet, pero sí seguir recibiendo correos electrónicos a la cuenta institucional (y quizás ya no pueda mandar correos desde esta cuenta).

En servicios gestionados automáticamente, en general, servicios con una ingente cantidad de usuarios, el procedimiento de baja puede llegar a ser automático: cuando un usuario se registra, se le advierte de que, por ejemplo, su cuenta de usuario caducará si no ha realizado ninguna actividad durante un

determinado periodo de tiempo. No está de más que, en un sistema de este tipo, se manden algunos mensajes de recordatorio al usuario antes de que la cuenta caduque.

2.3.2. Baja de certificados electrónicos

En cuanto a certificados electrónicos, la baja de la identidad digital implica otros conceptos y escenarios:

- **Un certificado puede caducar.** Si la fecha en que se usa un certificado está fuera del periodo de validez, se avisará al propietario del certificado de un modo u otro. El administrador de un servicio debe prever la caducidad de los certificados de servidor de sus sistemas y renovarlos antes de que caduquen para no perjudicar a los usuarios.
- **Un certificado ve comprometida su seguridad.** Por ejemplo, si se pierde un DNle, o bien el usuario cree que ha habido una usurpación de la clave privada o del código de acceso, se debe proceder con una **revocación** del certificado.

Hay distintas técnicas para tratar con certificados revocados. En primer lugar, el usuario deberá pedir la revocación del certificado mediante un trámite con el emisor del certificado.

Ahora bien, también es importante que la revocación sea notificada a los potenciales usuarios del certificado. Para resolver este problema existe el concepto de **lista de revocación** (CRL¹²). Una CRL contiene una lista de **números de serie** de certificados revocados por su autoridad de certificación.

⁽¹²⁾CRL es la sigla de *certificate revocation list*.

Si se desea comprobar la validez de un certificado, se debe descargar una CRL actualizada. La dirección web de donde descargar esta lista se indica en uno de los campos del certificado digital. La gestión de las CRL forma parte de las plataformas PKI. Aunque las CRL son un mecanismo de comprobación ampliamente usado, la obtención e interpretación de la lista de revocación acarrea cierta complejidad. El protocolo OCSP¹³ es un protocolo que informa de la validez de un certificado en concreto: se realiza una petición a un servidor OCSP *responder* y este nos informará de la validez de un certificado. Así pues, se evita la descarga e interpretación (*parsing*) de una lista de certificados revocados.

⁽¹³⁾OCSP es la sigla de *online certificate status protocol*.

3. Control de acceso

Desde tiempos antiguos, los humanos se han protegido a sí mismos y a sus recursos (alimentos, herramientas, etc.) mediante una gran variedad de sistemas. Probablemente, una de las formas más primitivas de proteger sus vidas y sus recursos fue el uso de cuevas. Estas les permitían guarecerse del frío y de los elementos, a la vez que dificultaban los ataques de depredadores. El tamaño de las cuevas y, en especial, el de sus entradas resultaba de vital importancia para los primeros humanos. Diversos estudios muestran que las cuevas con entradas pequeñas (más fáciles de controlar) eran usadas para realizar actividades secretas (*holderness* y otros).

El control de acceso ha sido históricamente un problema eminentemente físico. Murallas, fosos, puentes destruibles, puentes levadizos, puertas y verjas son solo algunos ejemplos de elementos arquitectónicos que a lo largo de la historia han sido usados para controlar el acceso a espacios y recursos. El control de acceso, entendido desde un punto de vista físico, se ha implementado en gran medida mediante el uso de llaves y puertas. Los recursos se almacenan en áreas solo accesibles por medio de puertas que pueden ser abiertas únicamente con determinadas llaves. Así, solo los poseedores de las llaves adecuadas podrán acceder a los recursos.

Aunque el control de acceso físico es aún una realidad ineludible. ¿Quién no se ha olvidado las llaves alguna vez? Tras el advenimiento y la posterior generalización de las tecnologías de la información y de las comunicaciones, el control de acceso físico ha perdido protagonismo en favor del control de acceso lógico¹⁴ o virtual, relacionado con los sistemas de seguridad informática. En el texto que sigue nos centraremos en el estudio del control de acceso entendido desde este punto de vista.

El control de acceso es el proceso por el cual, dada una petición de recursos, se permite o niega el acceso a los mismos en base a la aplicación de unas políticas de acceso.

Protección de castillos y ciudades

Durante la Edad Media resultaba frecuente la protección de castillos y ciudades mediante el uso de puentes destruibles o levadizos que permitían cruzar un foso y acceder a un recinto a menudo amurallado.

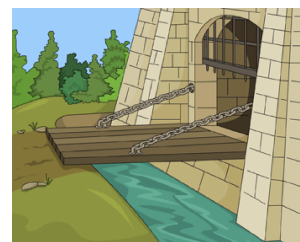


Figura 17. Puente levadizo

⁽¹⁴⁾Usado el término *lógico* en el sentido informático, en contraposición a *físico*.

Ved también

El concepto de *políticas de acceso* como conjunto de reglas que rigen el control de acceso se explica detalladamente en el subapartado 3.2. de este módulo.

El control de acceso comprende mecanismos de autenticación, autorización y auditoría. Sus principales objetivos son proteger datos y recursos frente al acceso no autorizado (proteger el secreto) y frente a una modificación no autorizada (proteger la integridad), así como garantizar el acceso de los usuarios legítimos a los recursos (no denegación de servicio). Con el fin de conseguir estos objetivos, se controlan todos los accesos al sistema y sus recursos, y solo se permite que tengan lugar aquellos autorizados. Haciendo un símil con los sistemas físicos, en concreto, los puentes levadizos y los puentes destruibles, podemos observar que ambos puentes cumplen con los dos primeros objetivos (proteger el secreto y la integridad). Sin embargo, los puentes destruibles no satisfacen el tercer objetivo puesto que al destruirse no pueden ser cruzados por nadie, lo que provoca una denegación de servicio para las peticiones autorizadas.

Los sistemas de control de acceso deben ser entendidos como mecanismos de monitorización capaces de interceptar todas las peticiones de recursos que llegan al sistema. Estos sistemas de control deben cumplir con los siguientes requisitos:

- **Resistencia a manipulaciones.** El sistema no puede ser alterado o manipulado y, si lo es, dicha alteración debe ser detectable. En el caso de que no sea así, el sistema no sería seguro, ya que podría permitir el acceso no autorizado a recursos de forma inadvertida.
- **No eludible.** El sistema no puede ser saltado, es decir, todo acceso debe producirse por medio de él. En caso de no cumplirse esta condición, el sistema no sería seguro, dado que habría peticiones de recursos que no serían analizadas y darían lugar a posibles accesos no autorizados.
- **Seguridad nuclear.** La seguridad del sistema debe concentrarse en un núcleo y no distribuirse por el sistema informático. De no ser así, todo el código del sistema informático debería ser validado por todos los puntos de acceso y se crearía, así, una sobrecarga innecesaria.
- **Tamaño pequeño.** El sistema debe ser lo suficientemente pequeño para permitir la prueba formal de su seguridad.

Demostraciones formales

Gracias a las demostraciones formales podemos probar las propiedades de seguridad de un modelo sin necesidad de implementarlo. Así, si el modelo es fiel a la realidad, el sistema resultante, tras su implementación, mantendrá las mismas propiedades de seguridad.

Políticas de seguridad

Las políticas de seguridad son el conjunto de reglas que regulan el acceso a los recursos del sistema.

3.1. Fases del desarrollo de un sistema de control de acceso

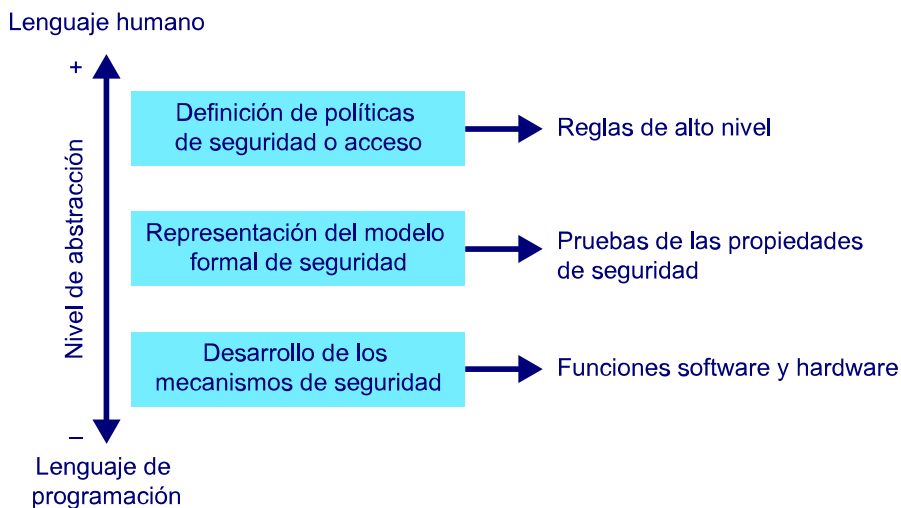
El desarrollo de un sistema de control de acceso suele tener las tres fases siguientes:

- 1) la definición de las políticas de seguridad,
- 2) la representación mediante un modelo formal, y

3) la implementación de los mecanismos de seguridad.

Las tres fases, que se asemejan a las del proceso de desarrollo de software, se muestran gráficamente en la figura siguiente:

Figura 18. Abstracción y fases de desarrollo de un sistema de control de acceso



Durante la primera fase del proceso (**definición de políticas de seguridad**) se establece, mediante lenguaje natural, el conjunto de reglas que regulan el acceso a los recursos del sistema de forma abstracta. En esta fase del proceso, las reglas pueden ser vagas e incluso ambiguas, ya que a menudo hacen referencia a leyes, procesos de funcionamiento propios y procedimientos organizacionales. Esta ambigüedad hace que las reglas, en esta fase, deban ser interpretadas y no sean aptas para un sistema informático. Por ejemplo, podríamos considerar la regla «Todos los ingenieros de nivel avanzado tienen acceso al ordenador central», en este caso «nivel avanzado» es un concepto vago que posteriormente deberá ser formalizado.

En la segunda fase del proceso (**representación del modelo formal de seguridad**) se representa formalmente el conjunto de reglas y su funcionamiento. Esta formalización permite demostrar que un sistema cumple con un determinado conjunto de propiedades de seguridad. Uno de los primeros modelos de seguridad que se propusieron fue el de Bell-LaPadula (Bell; LaPadula, 1973). Posteriormente apareció el modelo HRU de Harrison, Ruzzo y Ullmann, en 1976, que formalizó, entre otros, el concepto de *matriz de acceso* (Harrison y otros, 1976).

Ved también

El concepto de *matriz de acceso* se explica detalladamente en el subapartado 3.3. de este módulo.

Finalmente, la tercera fase del proceso (**desarrollo de los mecanismos de seguridad**) consiste en la implementación del modelo mediante el uso de lenguajes de programación, que son interpretados de forma determinista y sin ambigüedad por un sistema informático.

3.2. Políticas de acceso: concepto y elementos básicos

Todo sistema de control de acceso considera los siguientes elementos básicos:

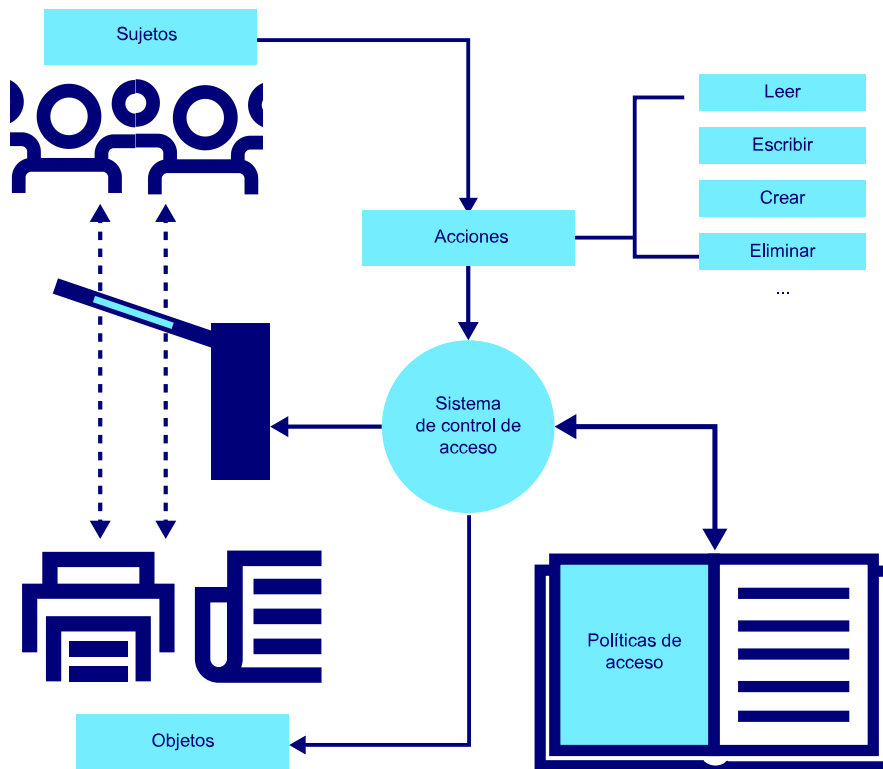
- **Objetos** (también llamados *objetivos*). Son todas aquellas entidades de un sistema susceptibles de ser protegidas. En el caso de un sistema operativo pueden ser: archivos, directorios, programas, dispositivos, terminales, puertos, etc. En el caso de una base de datos, tenemos tablas, relaciones, vistas, procedimientos, etc.
- **Acciones**. Todo aquello que se puede realizar sobre un objeto. Las acciones típicas que podemos realizar sobre un fichero son: lectura, escritura, creación, eliminación. En el caso de que el objeto sobre el que se realiza la acción sea un programa, cabría añadir la opción de ejecución.
- **Sujetos** (también llamados *iniciadores*). Es cualquier entidad con capacidad para requerir el acceso a objetos del sistema. Los sujetos típicos de un sistema son sus usuarios y los procesos del sistema (por ejemplo, un navegador web, un procesador de textos, etc.).

En todo sistema informático, los sujetos realizan acciones sobre los objetos. El sistema de control de acceso es el encargado de decidir si un determinado sujeto tiene permiso para ejecutar una determinada acción sobre un determinado objeto. La decisión de permitir o denegar el acceso a los recursos se realiza en base a las políticas de acceso.

Las políticas de acceso son el conjunto de reglas que permiten determinar si un sujeto puede realizar una determinada acción (lectura, escritura, modificación, eliminación o ejecución) sobre un objeto.

La figura siguiente muestra un esquema de los componentes principales de un sistema y su interacción con el sistema de control de acceso. Obsérvese cómo el sistema de control de acceso (en el centro de la figura) recibe peticiones de los sujetos para realizar acciones, evalúa estas peticiones mediante el uso de una política de acceso y actúa en consecuencia permitiendo o denegando el acceso a los objetos.

Figura 19. Elementos básicos de un sistema de control de acceso y su interacción



3.3. Tipos de control de acceso

En función de cómo se aplican y gestionan las políticas de acceso podemos distinguir tres tipos fundamentales de control de este:

1) **Control de acceso obligatorio.** Las políticas son evaluadas por el sistema, entendido como un único ente central. Los sujetos del sistema no pueden rehacer o redefinir las políticas. Por ejemplo, no pueden dar permisos de acceso a otros usuarios. Los objetos y sujetos del sistema pertenecen a diversas clases de acceso. Así, para acceder a un objeto de una determinada clase, hace falta que el sujeto pertenezca a una clase igual o superior (en términos de privilegios). Este tipo de acceso se inspira en el funcionamiento militar, en el que la información (por ejemplo, planes de ataque) solo puede ser vista por aquellas personas que gozan de un nivel de seguridad suficiente (por ejemplo, nivel de coronel).

2) **Control de acceso discrecional.** Las políticas son gestionadas por los propietarios (sujetos) de los recursos (objetos). Los sujetos pueden modificar las políticas asociadas a los objetos del sistema. Por ejemplo, un propietario de un determinado objeto del sistema puede dar privilegios de acceso sobre ese objeto a otro sujeto. Este tipo de control de acceso es usado generalmente por los sistemas operativos.

3) Control de acceso basado en roles. Las políticas son definidas por el sistema, pero, a diferencia de las políticas de acceso obligatorio, el acceso no se evalúa en función de permisos individuales, sino mediante permisos de clase (o de rol). Cada rol tiene asignados ciertos privilegios y cada sujeto del sistema tiene asignado un rol, así el sujeto adquiere los privilegios del rol al que pertenece. Este tipo de control de acceso es un caso general de los dos anteriores. Suele usarse para la gestión de acceso a recursos de bases de datos.

Nota

El control de acceso obligatorio y el control de acceso discrecional pueden verse como casos particulares de un modelo de control de acceso basado en roles.

En los siguientes subapartados describiremos con más detalle las características de estos sistemas de control de acceso y algunos otros menos habituales.

3.3.1. Control de acceso obligatorio

En un sistema control de acceso obligatorio (MAC¹⁵), las políticas son evaluadas de forma centralizada por una autoridad (en el caso de un sistema operativo, el encargado estaría en el núcleo de este). Típicamente se usan sistemas de seguridad multinivel basados en clasificaciones de los sujetos y los objetos del sistema. Todos los sujetos y objetos tienen asignada una **clase de acceso**.

⁽¹⁵⁾MAC son las siglas en inglés de *mandatory access control*.

Una clase de acceso es un elemento de un conjunto de clases parcialmente ordenado, donde el orden viene dado por una relación de dominancia representada por $\geq$.

En su forma más simple, un conjunto de clases de acceso se podría definir mediante un conjunto de etiquetas ordenadas. Sin embargo, en general, las clases de acceso vienen caracterizadas por dos componentes:

1) Nivel de seguridad (N). Es un elemento de un conjunto jerárquico ordenado. Por ejemplo, podríamos considerar los elementos: seguridad alta (SA), seguridad media (SM) y seguridad baja (SB), donde $SA > SM > SB$.

2) Conjunto de categorías (C). Es un subconjunto de un conjunto no ordenado cuyos elementos hacen referencia a áreas funcionales o de competencia. Por ejemplo, podríamos considerar los elementos: gestión, investigación, transferencia y docencia. En este caso el elemento *gestión* podría asociarse a objetos relacionados con la administración, contabilidad y recursos humanos, mientras que el elemento *investigación* o *transferencia* podría asociarse con objetos relacionados con laboratorios o equipos informáticos.

A partir de estos dos componentes (nivel de seguridad y conjunto de categorías) podemos definir la relación de dominancia como sigue.

Clases incomparables

Dadas dos clases c_1 , c_2 , si no se cumple que $c_1 \geq c_2$ ni que $c_2 \geq c_1$ se dice que las clases son incomparables.

La clase $c_1 \geq$ la clase c_2 si el nivel de seguridad de c_1 es mayor que el nivel de seguridad de c_2 y el conjunto de categorías de c_1 incluye al conjunto de categorías de c_2 . Formalmente:

$$\forall c_1 = (N_1, C_1), c_2 = (N_2, C_2): c_1 \geq c_2 \Leftrightarrow N_1 \geq N_2 \wedge C_1 \supseteq C_2$$

La relación de dominancia definida anteriormente cumple con las propiedades: reflexiva, transitiva, antisimétrica, existencia de cota superior y existencia de cota inferior.

La clase de acceso asociada a un objeto indica la **sensibilidad** de la información contenida en el objeto.

La sensibilidad de una determina información puede entenderse como el daño potencial que puede causar la revelación no autorizada de dicha información.

Por otro lado, la clase de acceso asociada a un sujeto indica su nivel de autorización formal (en inglés, *clearance*).

La autorización formal hace referencia al nivel de confianza en un sujeto. Puede verse como la confianza que se tiene en que el sujeto no revelará información sensible a sujetos sin autorización.

Así pues, el control de acceso obligatorio equivaldría a la restricción de acceso a objetos basada en la sensibilidad de la información contenida en los objetos y la autorización formal (*clearance*) de los sujetos para acceder a una información de ese nivel de sensibilidad.

3.3.2. Control de acceso discrecional

El **control de acceso discrecional** (DAC¹⁶) fue definido por el *Trusted Computer System Evaluation Criteria*, en 1985. Se basa en evaluar qué sujeto realiza la petición de acceso a los recursos y en un conjunto de reglas de acceso explícitas definidas por los propietarios (*owners*) de los objetos. En un sistema DAC todo objeto tiene un propietario, u *owner*, que es quien gestiona el acceso al mismo.

⁽¹⁶⁾DAC son las siglas en inglés de *discretionary access control*.

Recibe el nombre de *discrecional* debido a que los usuarios del sistema tienen la capacidad de transferir sus privilegios de acceso a otros usuarios. A diferencia del control de acceso obligatorio, el modelo DAC no usa un sistema centrali-

zado en el que solo una única autoridad otorga y revoca privilegios de acceso a los recursos. En consecuencia, resulta necesario el uso de políticas de administración.

En los sistemas DAC, las políticas de administración regulan los procesos de gestión de privilegios (por ejemplo, transmisión, revocación, etc.) entre los sujetos del sistema.

Una de las formas más comunes de definir los permisos que tiene cada sujeto sobre cada objeto es el modelo de matriz de acceso (propuesto en el modelo HRU). Este modelo, que fue inicialmente descrito por Lampson en el contexto de los sistemas operativos, y más tarde fue refinado por Graham y Denning, permite describir el control de acceso discrecional. Recibe el nombre de *modelo de matriz de acceso* porque usa una matriz para codificar el estado del acceso a los recursos en todo momento. Concretamente, cada celda $M(i,j)$ de la matriz, contiene las acciones que puede realizar el sujeto (i) sobre el objeto (j).

Modelo HRU

El modelo de matriz de acceso fue formalizado por Harrison, Ruzzo y Ullmann y se conoce como *modelo HRU*.

Ejemplo de matriz de acceso

La tabla siguiente muestra un ejemplo de matriz de acceso en la que pueden identificarse tres sujetos (Ana, Bernardo y Carlos), que podrían ser usuarios del sistema, y cuatro objetos (*Archivo1*, *Archivo2*, *Ejecutable1* y *Ejecutable2*). Si observamos la celda de la matriz correspondiente a la intersección entre el sujeto (Ana) y el objeto (*Archivo2*), podemos ver que las acciones permitidas son lectura y escritura. Además, también podemos observar que Ana es la propietaria del *Archivo2*, lo cual le confiere la potestad de otorgar privilegios sobre este objeto a otros sujetos del sistema.

Tabla 1. Matriz de acceso

	<i>Archivo1</i>	<i>Archivo2</i>	<i>Ejecutable1</i>	<i>Ejecutable2</i>
Ana	Lectura Escritura	Lectura Escritura Propiedad		Ejecución
Bernardo		Lectura	Ejecución	
Carlos				Ejecución

El estado de la matriz de acceso puede ser modificado mediante el uso de comandos que ejecutan funciones primitivas sobre el estado de las autorizaciones. Concretamente, el modelo HRU considera seis funciones primitivas:

- 1) adición y supresión de sujetos
- 2) adición y supresión de objetos
- 3) adición y supresión de privilegios

La representación de la matriz de acceso en su forma más simple, es decir, mediante una tabla bidimensional, resulta altamente ineficiente cuando el número de sujetos y objetos del sistema crece.

Obsérvese que, si el número de sujetos y objetos es grande, es probable que la mayoría de las celdas de la matriz estén vacías (puesto que no todos los sujetos tienen acceso a todos los objetos). Por ello se usan formas de representación alternativas espacialmente más eficientes como las siguientes:

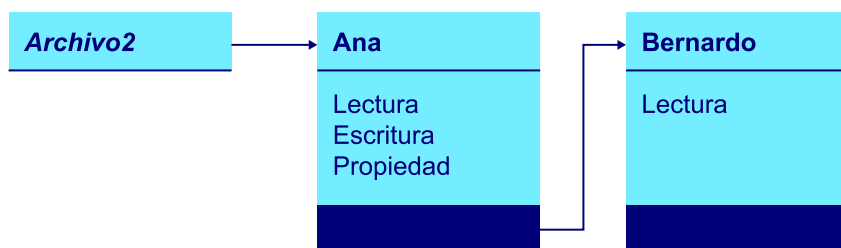
1) Tablas de autorización. Son tablas con tres columnas (sujeto, acción, objeto) que incluyen todas las celdas no vacías de la matriz de acceso. Así, cada tupla de la tabla representa la capacidad que tiene un sujeto de realizar una acción sobre un objeto. La tabla siguiente muestra la representación mediante una tabla de autorización de la matriz de acceso de la tabla anterior.

Tabla 2. Representación mediante tabla de autorización

Sujeto	Acción	Objeto
Ana	Lectura	<i>Archivo1</i>
Ana	Escritura	<i>Archivo1</i>
Ana	Lectura	<i>Archivo2</i>
Ana	Escritura	<i>Archivo2</i>
Ana	Propietaria	<i>Archivo2</i>
Ana	Ejecución	<i>Ejecutable2</i>
Bernardo	Lectura	<i>Archivo2</i>
Bernardo	Ejecución	<i>Ejecutable1</i>
Carlos	Ejecución	<i>Ejecutable2</i>

2) Listas de control de acceso. Son listas enlazadas que representan la matriz de acceso por columnas. De este modo, dado un determinado objeto (por ejemplo, el *Archivo2*) se puede determinar si un sujeto (por ejemplo, Bernardo) tiene permiso para realizar alguna acción sobre él (por ejemplo, leerlo). El siguiente gráfico muestra la lista de control de acceso para el *Archivo2* según la matriz de acceso de ejemplo de la primera tabla de nuestro ejemplo.

Figura 20. Ejemplo de listas de control de acceso



3) Listas de capacidades. Son listas enlazadas que representan la matriz de acceso por filas. De este modo, dado un determinado sujeto (por ejemplo, Bernardo) se puede determinar si puede realizar una acción (por ejemplo, ejecu-

ción) sobre un determinado objeto (por ejemplo, el *Ejecutable1*). El siguiente gráfico muestra la lista de capacidades de **Bernardo** según la matriz de acceso de ejemplo de la primera tabla.

Figura 21. Lista de capacidades



3.3.3. Control de acceso basado en roles

Cuando se trabaja con organizaciones grandes resulta poco práctico tener que definir los privilegios de acceso de forma individualizada.

Ejemplo: bufete de abogados

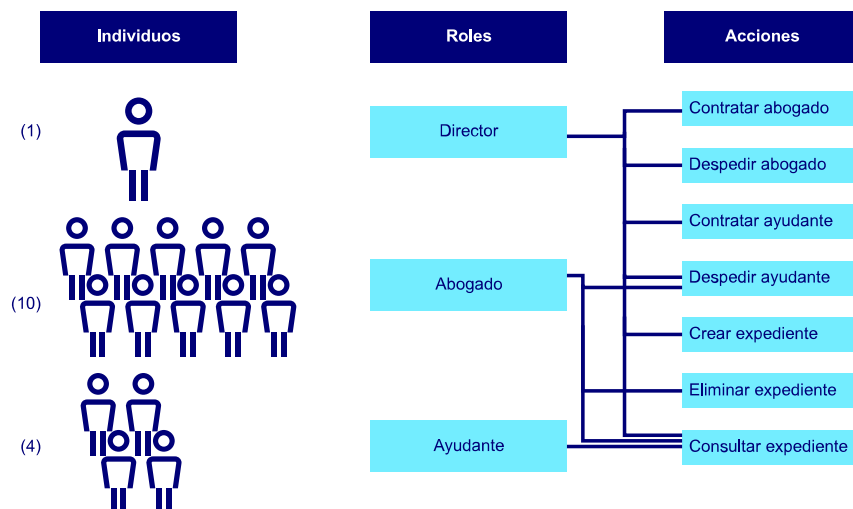
Tomemos como ejemplo un bufete de abogados formado por quince trabajadores, de los cuales uno es el director, diez son abogados y cuatro son ayudantes. Supongamos que las acciones que se realizan en el bufete son las siguientes:

- contratar o despedir abogados
- contratar o despedir ayudantes
- crear o eliminar expedientes
- consultar expedientes

En el bufete el director puede realizar todas las acciones, los abogados pueden crear, eliminar y consultar expedientes y los ayudantes solo pueden consultar los expedientes.

La figura siguiente muestra gráficamente los usuarios (trabajadores) del bufete, sus roles y las acciones que pueden realizar. Es fácil observar que la definición de las acciones que puede realizar cada trabajador de la empresa es más cómoda si se considera el rol que desempeña en la empresa (y, por consiguiente, las tareas que realiza). Por ejemplo, no es necesario definir las acciones que puede realizar cada abogado de forma individual, sino que simplemente hace falta definir qué acciones puede hacer un abogado «genérico».

Figura 22. Usuarios, roles y acciones para el ejemplo del bufete de abogados



El **control de acceso basado en roles** (RBAC¹⁷) se fundamenta en la idea de asignar permisos o privilegios para realizar acciones a roles en vez de a sujetos del sistema. Así, cada sujeto del sistema tiene un rol asignado y puede realizar todas aquellas acciones para las que su rol tiene privilegios.

⁽¹⁷⁾RBAC son las siglas en inglés de *role-based access control*.

Un rol es la función que alguien o algo cumple. Por ejemplo, en los sistemas operativos suele hacerse una clara distinción entre el rol de administrador y el rol de usuario básico.

Obsérvese que la gestión de los permisos se simplifica claramente respecto a los anteriores modelos, puesto que una vez asignados los permisos a los roles, la única tarea consiste en asignar correctamente los roles a los sujetos del sistema.

El modelo de control de acceso basado en roles es lo suficientemente flexible como para funcionar como el control de acceso obligatorio y el control de acceso discrecional. En realidad, podemos considerar que tanto el modelo MAC como el DAC son casos particulares del modelo RBAC.

Resumen

En este módulo hemos estudiado el concepto de *autenticación de la identidad* y hemos revisado cuáles son las técnicas básicas para implementarla, el ciclo de vida de la identidad digital y el control de acceso.

En primer lugar, hemos visto el uso de contraseñas para la autenticación de los usuarios. Hemos estudiado el concepto de *certificado electrónico* y revisado de forma resumida el concepto de *clave pública* y las propiedades de seguridad de la información que permite alcanzar. El concepto de *certificado electrónico* ha servido para presentar el concepto de *firma electrónica*, de la cual hemos estudiado aspectos legales y de implementación con PDF y XML. También hemos realizado un repaso de los dispositivos de usuario para el soporte a los procesos de autenticación viendo distintos tipos de *token*. Hemos presentado el concepto de *tarjeta inteligente* y detallado su uso en el DNI electrónico. Finalmente, hemos presentado la biometría como un conjunto de técnicas capaces de identificar a individuos, o bien ayudar a su autenticación.

También se ha expuesto el tema del ciclo de vida de la identidad digital, estudiando conceptos como la *gestión y creación de contraseñas*, los problemas que esto conlleva y sus posibles soluciones. Hemos visto en detalle los procesos de autenticación mediante certificados electrónicos e introducido el concepto de *single sign-on*. Finalmente, hemos tratado la baja de usuarios, desde el punto de vista de usuarios autenticados con contraseña y desde el punto de vista de revocar certificados electrónicos.

A continuación, hemos estudiado los sistemas de control de acceso. Tras presentar el concepto desde un punto de vista histórico y mostrar su vertiente más física, hemos descrito cómo la aparición de las TIC nos obliga a estudiar los sistemas de control de acceso desde un punto de vista de seguridad informática.

Finalmente, se ha analizado el concepto de *política de acceso* y descrito los principales actores que forman parte del sistema, es decir, objetos, sujetos y acciones. Hemos presentado los tres tipos fundamentales de control de acceso, es decir, control de acceso obligatorio (MAC), control de acceso discrecional (DAC) y control de acceso basado en roles (RBAC).

Bibliografía

Bell, D. E.; LaPadula, L. J. (1973). «MITRE Documento Técnico 2547 (vol. 1)». *Secure Computer Systems: Mathematical Foundations* (versión digital actualizada por Len LaPadula en 1996).

Cloud Signature Consortium (abril de 2021). *Building a standard for cloud signatures*. <https://cloudsignatureconsortium.org>

Departamento de Defensa de los EE. UU. (1985). *Trusted Computer System Evaluation Criteria*. DoD Standard 5200.28-STD.

Dirección General de Policía, Gobierno de España (abril de 2021). *Portal DNI Electrónico*. www.dnielectronico.es/PortalDNIe/

ETSI (2009). *Electronic Signatures and Infrastructures (ESI); PDF Advanced Electronic Signature Profiles (PAAdES) (ETSI TS 102 778)*. <https://www.etsi.org/deliver/etsi_ts/102700_102799/10277803/01.02.01_60/ts_10277803v010201p.pdf>

ETSI (2009). *XML Advanced Electronic Signatures (XAAdES) (ETSI TS 101 903)*. <https://www.etsi.org/deliver/etsi_ts/101900_101999/101903/01.04.02_60/ts_101903v010402p.pdf>

Gollmann, D. (2005). *Computer Security* (2.^a ed.). Chichester (West Sussex): John Wiley & Sons.

Harrison, M. A.; Ruzzo, W. L.; Ullman, J. D. (1976). «Protection in Operating Systems». *Communications of the ACM* (núm. 19 (8), págs. 461-471).

Holderness, H.; Davies, G.; Chamberlain, A.; Donahue, R. (2006). «A Conservation Audit of Archaeological Cave Resources in the Peak District and Yorkshire Dales». Documento Técnico. CAPRA.

ISO (2009). *Common Criteria for Information Technology Security Evaluation (ISO-IEC-15408)*. <<https://www.iso.org/standard/50341.html>>

Parlamento Europeo y Consejo de la Unión Europea (2014). *REGLAMENTO (UE) No 910/2014 DEL PARLAMENTO EUROPEO Y DEL CONSEJO de 23 de julio de 2014 (eIDAS)*. <<https://www.boe.es/doue/2014/257/L00073-00114.pdf>>

Samarati, P.; De Capitani di Vimercati, S. (2001). «Access Control: Policies, Models, and Mechanisms». *FOSAD. Lecture Notes in Computer Science* (vol. 2171/2001, págs. 137-196).

Stallings, W. (2008). *Computer security: principles and practice*. Upper Saddle River (New Jersey): Pearson/Prentice Hall.

Windley, P. (2005). *Digital Identity*. Sebastopol (California): O'Reilly.

